

- **Expediente N.º: EXP202304294**

RESOLUCIÓN DE PROCEDIMIENTO SANCIONADOR

Del procedimiento instruido por la Agencia Española de Protección de Datos y en base a los siguientes

ANTECEDENTES

PRIMERO: **A.A.A.** (en adelante, la parte reclamante) con fecha 13 de febrero de 2023 interpuso reclamación ante la Agencia Española de Protección de Datos. La reclamación se dirige contra VODAFONE ESPAÑA, S.A.U. con NIF A80907397 (en adelante, la parte reclamada, Vodafone o Lowi). Los motivos en que basa la reclamación son los siguientes:

La parte reclamante manifiesta que el día 7 de febrero de 2023, no consiguió acceder a sus cuentas bancarias mediante la huella biométrica y tampoco entrando con su clave, ya que figuraba errónea.

Posteriormente, tras solicitar el restablecimiento de sus contraseñas, no recibe mensaje o código alguno, comprobando que no tenía señal en su línea de teléfono. Después de contactar con Lowi, le informan que habían solicitado un duplicado de la tarjeta SIM de su teléfono móvil a través de su área privada.

Y, adjunta la siguiente documentación relevante:

Denuncia de los hechos ante la comisaría de Policía Nacional de Fuengirola: atestado 1928/2023, de 8 de febrero.

Cargos bancarios efectuados en su cuenta bancaria de forma fraudulenta.

SEGUNDO: De conformidad con el artículo 65.4 de la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales (en adelante LOPDGDD), se dio traslado de dicha reclamación a la parte reclamada, para que procediese a su análisis e informase a esta Agencia en el plazo de un mes, de las acciones llevadas a cabo para adecuarse a los requisitos previstos en la normativa de protección de datos.

El traslado, que se practicó conforme a las normas establecidas en la Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas (en adelante, LPACAP), fue recogido en fecha 10 de abril de 2023 como consta en el acuse de recibo que obra en el expediente.

Con fecha 5 de junio de 2023 se recibe en esta Agencia escrito de respuesta indicando:

<<en fecha 7 de febrero de 2023 el reclamante tiene constancia de la solicitud de un duplicado SIM realizada desde su área privada de cliente, a la cual se accede mediante la dirección de correo electrónico o número de teléfono móvil y la contraseña establecida. Dicha petición se realizó desde el área privada del cliente el día 6 de febrero de 2023, previa autenticación del usuario, sin que LOWI tuviese constancia previamente de un acceso indebido al área de cliente, ni de un acceso no autorizado a los datos del cliente, constando únicamente de manera previa dos llamadas telefónicas a los servicios de atención al cliente en las que se solicitaba la modificación en la dirección de correo electrónico del cliente, vinculada al acceso a su área privada.

En dichos contactos realizados telefónicamente, el trámite de cambio de dirección de correo electrónico no pudo ser completado con éxito, ya que el solicitante no aportó correctamente toda la información que prevé la Política de Seguridad para la verificación de la identidad (en particular, la comprobación de la cuenta bancaria vinculada al servicio contratado). Ello no implica, en principio, ninguna presunción de actuación fraudulenta o ajena al titular del servicio, sino que simplemente conlleva la imposibilidad de realizar el trámite solicitado a través de ese canal.

En este sentido y a efectos aclaratorios acerca del funcionamiento de la Política de Seguridad, se aporta, copia de la grabación telefónica del trámite referido, en el que se solicita el cambio de dirección de correo electrónico del reclamante.

Posteriormente, se realizó un ulterior contacto telefónico al Servicio de Atención al Cliente en la que el solicitante del trámite superó lo dispuesto en la Política de Seguridad para la verificación de la identidad y, en consecuencia, se procedió a la tramitación de su cambio de dirección de correo electrónico.

En todo caso, LOWI no ha detectado ningún acceso no autorizado por parte de un tercero a sus sistemas internos o bases de datos en los que se almacenan los datos del reclamante, ni ningún otro incidente que haya supuesto la fuga de datos o contraseñas del reclamante.

Así las cosas, entendemos que lo ocurrido queda fuera del ámbito de responsabilidad de mi mandante pues los clientes o interesados tienen la responsabilidad de custodiar debidamente sus datos personales.

Tal y como se ha expuesto en la manifestación anterior, la realización de una petición de duplicado SIM a través del área privada de cliente en la app LOWI se supedita a la previa autenticación del cliente, mediante la introducción de la dirección de correo electrónico o número de teléfono móvil y la contraseña establecida. En todo caso, en la realización de esta tipología de trámites a través del área privada no se refleja la verificación de la identidad del solicitante del trámite, sino que simplemente se refleja el procesamiento o no de la petición efectuada y la fecha y hora de la misma.

Por otra parte, en cuanto a los intentos previos de acceso, tras las investigaciones practicadas, LOWI ha podido verificar, como se indicaba inicialmente, la tramitación de la modificación de la dirección de correo electrónico vinculada al área privada del reclamante, no así de intentos fallidos o de otras incidencias relacionadas con el acceso al área privada.

Desde el área privada de cliente en la app LOWI, para la realización de esta petición, se facilitó como dirección postal de entrega una dirección diversa a la dirección de facturación.

Posteriormente, el duplicado SIM es efectivamente entregado en la dirección indicada, en fecha 7 de febrero de 2023, a las 12:31 horas. Para dicha entrega, se requirió la identificación del receptor, quien en este caso proporcionó el nombre y apellidos y el DNI del reclamante, firmando el albarán de entrega como si fuese el propio reclamante.

En cuanto al envío a un domicilio diferente al del titular, es el cliente quien elige la dirección de entrega, que puede o no coincidir con su dirección de facturación.

No obstante, la dirección no se puede modificar una vez solicitado el duplicado, se debería cancelar el envío y solicitar otro nuevo. Para la entrega de la tarjeta SIM, los transportistas tienen instrucciones de únicamente entregarla al titular del servicio, verificando su identidad, firmando a tal efecto el albarán de entrega como evidencia y conclusión de la gestión.

Tras realizar las investigaciones oportunas sobre lo ocurrido y habiendo confirmado mi representada que se han realizado todas las actuaciones pertinentes con anterioridad a la notificación de la presente solicitud de información, se ha procedido a enviar una carta al reclamante mediante la cual se ha procedido a informarle sobre las gestiones que fueron llevadas a cabo por LOWI para solucionar la incidencia.

En lo que se refiere a la realización de transacciones bancarias de carácter fraudulento como las que pone de manifiesto el reclamante en su reclamación, resulta oportuno expresar que el cambio de una tarjeta SIM implica únicamente el acceso a la línea de teléfono asociada a ésta, y no a los datos bancarios del titular. Por tanto, no parece posible que exista una correlación entre los hechos ocurridos en relación con mi representada y lo ocurrido con la entidad bancaria de la que es cliente el reclamante>>.

TERCERO: Con fecha 13 de mayo de 2023, de conformidad con el artículo 65 de la LOPDGDD, se admitió a trámite la reclamación presentada por la parte reclamante.

CUARTO: La Subdirección General de Inspección de Datos procedió a la realización de actuaciones previas de investigación para el esclarecimiento de los hechos en cuestión, en virtud de las funciones asignadas a las autoridades de control en el artículo 57.1 y de los poderes otorgados en el artículo 58.1 del Reglamento (UE) 2016/679 (Reglamento General de Protección de Datos, en adelante RGPD), y de conformidad con lo establecido en el Título VII, Capítulo I, Sección segunda, de la LOPDGDD, teniendo conocimiento de los siguientes extremos:

La investigación ha permitido acreditar que quien logró acceder al área privada de la parte reclamante (en adelante, "otro" u "otros") conocía previamente algunos de sus datos personales, pero no sus credenciales de acceso (número de teléfono o correo electrónico, y contraseña), y que accedió al área privada solo tras conseguir que se modificaran las mismas durante una llamada al servicio de atención al cliente (en

adelante “SAC de Lowi”) en la que la parte reclamada, no siguió completamente lo establecido en su propia política de seguridad.

La parte reclamada envía un correo a la parte reclamante el 29 de mayo en el que manifiesta que califica el suceso como fraude, pero que considera que quien logró acceder a su área privada ya conocía la contraseña de acceso:

*“En este sentido, le informamos de que, tras las investigaciones practicadas, se ha concluido que la incidencia acaecida en relación con su línea telefónica *****TELÉFONO.2** y las actuaciones no reconocidas por Usted han sido calificadas como fraudulentas por el Departamento de Fraude de Vodafone. En todo caso, la petición del duplicado SIM realizada de manera fraudulenta consta realizada desde el área privada de cliente, lo que indica que el presunto defraudador tuvo acceso a su información de usuario y a la contraseña de acceso a su perfil online.”*

Sin embargo, la parte reclamada no ha acreditado que quien logró acceder al área privada de la parte reclamante y activar una SIM de su titularidad conociera datos personales de la parte reclamante por falta de responsabilidad de ésta, ni tampoco que conociera su contraseña de acceso.

Se ha podido acreditar que se impidió en varias ocasiones la modificación de credenciales de acceso al otro u otros el 2 de febrero de 2023, así como a la propia parte reclamante el 10 de febrero.

Sin embargo, el 2 de febrero de 2023 en una llamada al SAC de Lowi, el otro u otros consiguió eludir el procedimiento establecido en la política de seguridad. Disponía del nombre y número de DNI de la parte reclamante, y conocía su número de teléfono, y de forma inexacta los últimos dígitos de la cuenta bancaria en ese momento inscrita (en las grabaciones se aprecia que se equivocan en un dígito), pero no la contraseña de acceso al área privada ni tampoco tenía acceso a ningún teléfono de los registrados en el área privada para recibir una llamada del SAC de Lowi.

En esa misma llamada el otro u otros consiguió que se modificaran las credenciales de acceso (correo electrónico y contraseña), con lo que pudo acceder al área privada de la parte reclamante. También estableció una palabra de seguridad. Con las credenciales de acceso, obtuvo la capacidad de solicitar desde el área privada un duplicado de tarjeta SIM.

Queda también acreditado que ese mismo día 2 de febrero de 2023 el otro u otros pudo averiguar en su acceso al área privada otros datos de la parte reclamante (al menos, los del contrato), y que modificó al menos la dirección postal por otra de su conveniencia y añadió el número de contacto *****TELÉFONO.1**. Queda igualmente acreditado que ese día solicitaron el envío de una tarjeta SIM a la nueva dirección postal establecida.

La parte reclamada manifiesta que hubo las siguientes solicitudes de tarjeta SIM para la línea principal de la parte reclamante:

“Tras una exhaustiva investigación en los sistemas internos de mi representada se ha comprobado que, durante las fechas indicadas, en enero y abril de 2023, se realizaron

*distintos intentos de duplicados SIM en la línea del reclamante con numeración ***TELÉFONO.2.*

Dichos duplicados fueron cancelados en su momento, excepto uno de ellos que corresponde con la tarjeta SIM que tiene actualmente activada el cliente.

En concreto se realizaron los siguientes duplicados SIM:

El 2 de febrero de 2023 se solicita un duplicado SIM desde la app de mi Lowi a las 13:58 horas, donde para acceder ha tenido que aportar previamente sus credenciales (usuario y contraseña), y el cual es cancelado el 3 de febrero de 2023 a las 10:55 horas, tras haber contactado un Agente de Atención al Cliente de Lowi con el reclamante.

Posteriormente, el 6 de febrero de 2023 a las 15:45 horas, se solicita una petición de un segundo duplicado SIM a través de la app de Mi Lowi, después de acreditarse a través de credenciales válidas. Este duplicado SIM es procesado.

Al día siguiente, el 7 de febrero de 2023 a las 20:29 horas, se solicita un duplicado SIM a través de la app de mi Lowi, siendo cancelado el 8 de febrero de 2023 a las 14:48 horas.

El 9 de febrero de 2023 a las 17:12 horas se tramita la solicitud de un duplicado SIM a través de la App de Lowi, Este pedido es cancelado el 10 de febrero de 2023 a las 14:52 horas.

El 13 de febrero de 2023 a las 13:43 horas, se solicita un duplicado a través de la App de Lowi. Este pedido figura cancelado el 14 de febrero de 2023 a las 14:37 horas, sin embargo, el reclamante contacta con los servicios de Atención al Cliente de Lowi, y comenta los motivos y dificultades que tiene para activar su tarjeta SIM por lo que el Agente, después de pasar la política de seguridad correctamente, se la activa.

Y, por último, se tramita un duplicado SIM el 16 de febrero de 2023 a las 16:36 horas desde la app de mi Lowi, este pedido es cancelado el mismo día y a las pocas horas de su solicitud, exactamente a las 20:26 horas.

Es relevante destacar que el duplicado efectuado en fecha 6 de febrero de 2023 ha sido calificado como fraudulento por parte del Departamento de Fraude de Lowi. En la ficha del cliente que consta en los sistemas internos de mi representada, figura un aviso en el que se indica que no deben realizarse ninguna modificación de datos si se llama desde un número dentro del parque contratado, con el fin de evitar que casos como estos puedan repetirse. La medida, evita que se produzcan intentos de duplicados SIM fraudulentos".

Queda acreditado que el primer envío de SIM resultó cancelado el 3 de febrero 2023 cuando ese día el SAC de Lowi contactó con la parte reclamante, llamando a su línea principal para que confirmara la activación de la SIM. La parte reclamante dejó de poder acceder a su área privada puesto que habían sido modificadas sus credenciales de acceso. En la grabación de la llamada entre el SAC de Lowi y la parte reclamante queda claro que el día anterior ya se había producido una primera suplantación de identidad.

En esa llamada se volvieron a establecer las credenciales de acceso y otros datos de la parte reclamante.

Queda acreditado que el día 6 de febrero el otro u otros, llamando al SAC de Lowi desde la línea que había quedado registrada como de contacto y disponiendo ya de los datos de la cuenta bancaria, consiguió que se modificaran de nuevo las credenciales de acceso al área privada de la parte reclamante, pudo modificar los datos, pidió el envío de una SIM y recibió la de numeración ICC *****REFERENCIA.1**. Queda acreditado que en esta ocasión consiguió activarla el 7 de febrero durante unas horas, como manifiesta la propia parte reclamada.

La parte reclamada no comprobó si previamente la línea estaba bloqueada o defectuosa, como recomienda su propia política.

La parte reclamada manifiesta respecto de la activación y entrega de tarjetas SIM en las fechas señaladas:

“(i) Comprobación en Mi Lowi: Los clientes de Lowi en caso de que quieran solicitar un duplicado SIM a través de la app de Mi Lowi deben introducir previamente y de manera correcta sus credenciales (usuario y contraseña) [...].

En el caso que nos ocupa, el solicitante de la SIM tuvo que introducir de manera correcta las credenciales de acceso, lo que le habilita para poder ingresar en el área privada del cliente. Las credenciales son personales e intransferibles, teniendo el propio cliente el deber de custodiarlas adecuadamente. Por lo que, se trata de un método de verificación de identidad que habilita al cliente, en el caso de que las ingrese de forma válida, el acceso a su área privada, donde puede solicitar y realizar los cambios que estime conveniente.”

Ya ha sido constatado que el otro u otros introdujo las credenciales que estableció tras lograr eludir los controles de seguridad de la parte reclamada el 2 de febrero de 2023, y que con ello completó la información que tenía antes de acceder por primera vez al área privada de la parte reclamante.

La parte reclamada también manifiesta en el documento:

“Es relevante destacar que el duplicado efectuado en fecha 6 de febrero de 2023 ha sido calificado como fraudulento por parte del Departamento de Fraude de Lowi. En la ficha del cliente que consta en los sistemas internos de mi representada, figura un aviso en el que se indica que no deben realizarse ninguna modificación de datos si se llama desde un número dentro del parque contratado [sic, se entiende que debería decir “fuera del parque contratado”], con el fin de evitar que casos como estos puedan repetirse. La medida, tal y como puede apreciarse en las grabaciones de las interacciones ejecutadas el 22 y 27 de febrero de 2023, y aportadas en el Documento número 1, evita que se produzcan intentos de duplicados SIM fraudulentos. Se adjunta pantallazo de la ficha de cliente de reclamante donde figura el aviso correspondiente.”

En el mencionado pantallazo aparece (esquina superior derecha) la palabra de seguridad que la parte reclamante estableció en la llamada de 7 de febrero, pero que no fue solicitada en varias llamadas, realizadas tanto por la propia parte reclamante

como por el otro u otros, los días 9, 10, 13, 14, 15 y 16 de febrero, como puede comprobarse en las grabaciones.

El 13 de febrero, el otro u otros consiguieron una vez más modificar las credenciales de acceso mediante llamada al SAC de Lowi y acceder después al área privada de la parte reclamante. Queda acreditado en la grabación, y por las manifestaciones de la parte reclamada.

La parte reclamada manifiesta también que el hecho constituye un fraude en:

“Asimismo, el 14 de febrero de 2023, el Departamento de Fraude de Lowi califica el duplicado SIM como fraudulento, procediendo a identificar al reclamante como víctima de fraude e incluyendo en su ficha de cliente el aviso aportado en las alegaciones presentadas el 11 de agosto de 2023.”

El mencionado aviso de fraude en el sistema de Lowi tampoco fue eficaz en la llamada del día 16 de febrero, en la que el otro u otros consigue de nuevo modificar las credenciales de acceso al área privada y después solicitar a través del área privada otro duplicado de SIM, cuyo envío fue posteriormente cancelado y se restablecieron las credenciales de la parte reclamante el día siguiente.

La parte reclamada ha proporcionado registros y grabaciones de llamadas con varios intentos más por parte del otro u otros tratando de modificar las credenciales de acceso los días 22 de febrero (2 intentos) y 27 de febrero (otros 5 intentos), que en estas ocasiones ya fueron impedidos gracias a la adecuada aplicación de la política de seguridad (en las dos primeras llamadas el llamante no conoce la palabra de seguridad, mientras que en las cinco últimas se le solicita que llame desde alguna de las líneas contratadas con Lowi).

Se solicitó a la parte reclamada acreditación documental del contrato con la empresa de transporte. Como respuesta aporta el documento, de Correos Express, en el que no consta fecha ni mención alguna de la parte reclamada. Por tanto, la parte reclamada no ha acreditado que existiera un encargo de tratamiento de datos personales con la empresa de transporte ni en su caso las condiciones del mismo.

La parte reclamada manifiesta haber modificado el 11 de agosto de 2023 su política de seguridad con posterioridad para evitar suplantaciones de identidad en relación con la tramitación de solicitudes de duplicados SIM.

QUINTO: De acuerdo con el informe recogido de la herramienta AXESOR, la entidad VODAFONE ESPAÑA, S.A.U. es una gran empresa constituida en el año 1.994, y con un volumen de negocios de 2.928.817.000 euros en el año 2022.

SEXTO: Con fecha 6 de febrero de 2024, la Directora de la Agencia Española de Protección de Datos acordó iniciar procedimiento sancionador a la parte reclamada, con arreglo a lo dispuesto en los artículos 63 y 64 de la Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas (en adelante, LPACAP), por la presunta infracción del Artículo 6.1 del RGPD, tipificada en el Artículo 83.5 del RGPD.

SÉPTIMO: Notificado el citado acuerdo de inicio conforme a las normas establecidas en, la LPACAP, la parte reclamada solicitó ampliación del plazo y copia del expediente y presentó escrito de alegaciones el día 28 de febrero de 2024 en el que, en síntesis, manifiesta: <<El responsable del tratamiento está sujeto a una obligación de medios, no a una obligación de resultados en el sentido de entender que todo incidente es un incumplimiento del deber de garantizar un nivel de seguridad adecuado al riesgo. Por tanto, el hecho de que un tercero, mediante la comisión de delitos, haya superado las medidas de seguridad de Vodafone no puede automáticamente inferirse que Vodafone no ha sido diligente en la verificación de la identidad del cliente y, por tanto, no ha tratado los datos personales del reclamante conforme al artículo 6.1 del RGPD. Es preciso poner de manifiesto que las medidas técnicas y organizativas implementadas por Vodafone están dirigidas única y exclusivamente a garantizar que el solicitante del duplicado de la tarjeta SIM es el titular de la línea telefónica contratada. En este sentido, todas las conductas realizadas por el estafador o ciberdelincuente en un estadio anterior a la solicitud del duplicado de la tarjeta SIM caen fuera de la esfera de control de Vodafone. En el presente caso, el duplicado de tarjeta SIM se produjo a través de la aplicación de Mi Lowi, lo que supone la previa obtención por parte de los estafadores o ciberdelincuentes, mediante fraude, ingeniería social o argucia, de determinados datos personales de los interesados, datos exigidos por Vodafone para verificar la identidad del titular de la línea.

El duplicado SIM que motiva el presente Acuerdo de Inicio, y el cual se tramita el 6 de febrero de 2023, es solicitado a través de la app de Mi Lowi, después de que el defraudador hubiera realizado una modificación de las credenciales de acceso, en concreto del correo electrónico, del área privada del reclamante

Que dicha modificación de datos fue realizada a través del Servicio de Atención al Cliente de Vodafone después de que el defraudador aportara correctamente los datos identificativos del reclamante exigidos para su superación, en concreto: • Nombre y apellidos; • DNI; • Correo electrónico con el que contaba previamente a la modificación; y • Ocho últimos dígitos de la cuenta bancaria.

Es relevante destacar que mi representada aportó a esta Agencia evidencia de la superación de dicha Política de Seguridad por parte del defraudador a través de la grabación 01_103_20230206131929_0511.

Por lo tanto, este tercero necesariamente tuvo que obtener toda esta información relativa al reclamante de manera previa a la realización de dicho trámite, superando la política de seguridad, la cual, tal y como indica esta Agencia, no se limita únicamente a “algunos de sus datos personales”, y que demuestra que defraudador conocía también el número de teléfono y correo electrónico del reclamante.

Con respecto a la contraseña, teniendo en cuenta la correcta superación de la Política de Seguridad por parte del defraudador, lo que impidió a mi representada identificar que el trámite estaba siendo realizado por un tercero ajeno al reclamante, y haciendo referencia de nuevo a lo indicado por mi representada, una vez que se modifica el correo electrónico, los clientes reciben en la nueva dirección de correo electrónico un email de recuperación de contraseña, debiendo asignar una nueva contraseña a su área privada de cliente.

En referencia al caso que nos ocupa, se aporta captura de pantalla del albarán de entrega donde se evidencia que el transportista siguió el proceso indicado, solicitando el DNI del reclamante por parte del transportista, introduciendo su numeración en el campo correspondiente y coincidiendo con la registrada en los sistemas internos de Vodafone. Asimismo, se debe tener en cuenta que todos los envíos de duplicados SIM que se realizan desde Vodafone siguen un método de entrega exclusiva, el cual es tipificado internamente en los sistemas de mi representada, así como en la orden de envío para el transportista con el número 89, que significa entrega exclusiva. Por lo que, si en el registro del envío el método de entrega consta identificado con dicha numeración, la misma se realizará siguiendo este método. Con respecto al caso que motiva el presente Acuerdo de Inicio, mi representada ha comprobado en sus sistemas internos que en la entrega del duplicado SIM fraudulento, fue categorizado internamente como “89 Entrega Exclusiva”, por lo que el transportista tuvo que solicitar el DNI a la persona receptora del mismo, realizando una verificación visual del documento y comprobando que la información ahí recogida coincidía con la del titular, el reclamante.

Sobre este proceso, el cliente de Lowi es informado con anterioridad a la entrega, previniéndole de la obligatoriedad de contar su DNI o NIE con el fin de que se lleve a cabo la entrega correctamente. Por lo que, en el caso que nos ocupa, la persona encargada de entregar la tarjeta SIM en cuestión tenía la obligación de verificar la identidad de quien que la recibió, comprobando que los datos identificativos de su DNI coincidían con los del envío. En este sentido, cabe resaltar que mi representada lanza recordatorios periódicos a la empresa de transporte con la que colabora con el fin de enfatizar el deber de que sus transportistas sigan el método de entrega exclusiva en todos aquellos envíos que se hayan categorizado con la calificación de 89.

Sin embargo, es relevante destacar que no es posible aportar evidencia documental que demuestre que el transportista solicitó el DNI o NIE, ya que para ello sería necesario proceder a la fotocopia del DNI o NIE del interesado y al almacenamiento del mismo.

En este sentido, del hecho de que un tercero, mediante la comisión de delitos, haya superado las medidas de seguridad de Vodafone no puede automáticamente inferirse que Vodafone no ha sido diligente en la verificación de la identidad de los clientes y, por tanto, no ha tratado los datos personales del reclamante conforme al artículo 6.1 del RGPD.

Por otra parte, si una vez entregada una tarjeta SIM, el cliente reporta una incidencia en su uso o activación, a fin de reducir el riesgo de fraude, la Política de Seguridad de Lowi prevé que se comprobará la identidad del solicitante, de acuerdo con lo previsto en dicha Política para su superación, y la correcta asignación de la tarjeta SIM en los sistemas de Lowi. Ante cualquier anomalía, si la solicitud consta realizada de manera presencial en otro establecimiento, desde el establecimiento del distribuidor autorizado deberán indicarle que el trámite deberá efectuarlo en el mismo establecimiento en que se solicitó el duplicado.

Además, para reducir el riesgo de cualquier actuación fraudulenta, Vodafone revisa y mejora continuamente su Política de Seguridad y las actuaciones de sus agentes y distribuidores autorizados.

El albarán de entrega del duplicado SIM se encuentra correctamente firmado, tal y como se ha podido evidenciar en la captura de pantalla aportada. Correos Express, entidad de transporte que, como esta Agencia ya conoce, fue la empleada para hacer llegar el duplicado SIM objeto de este acuerdo de inicio, tiene implementado un proceso de firma en el que el transportista, tal y como se ha indicado, debe solicitar el DNI o NIE de quien lo recoge, realizar una verificación visual del mismo comprobando que la información ahí recogida coincide con la de la persona a la que va dirigida el paquete y, en caso de que así sea, proceder a la entrega. Como prueba de ello, debe introducir el nombre y apellidos, así como el número de DNI o NIE en el propio albarán de entrega de manera electrónica a través de la tableta digital que se les facilita a los agentes de transporte. A este respecto, es importante puntualizar que el transportista no ha tenido conocimiento previo del número de DNI o NIE del titular del paquete hasta que no ha solicitado el DNI o NIE de aquel a quien lo entrega, y que es la propia aplicación que emplea Correos Express para la gestión de los envíos la que verifica de manera automática que los datos introducidos coinciden con los registrados en sistemas.

Como se puede comprobar en la captura de pantalla aportada del albarán de entrega del duplicado SIM que nos ocupa, en el apartado de la firma figura correctamente el nombre y el apellido del reclamante, así como su número de DNI. Tal y como se ha referido, esta información sólo pudo ser cumplimentada una vez que el transportista verificara el DNI del titular y después de que el sistema comprobara que los datos aportados coincidían con los del titular, no estando esta información pre-cubierta de ningún modo.

Así, Vodafone ha realizado el cambio de tarjeta SIM porque el solicitante ha acreditado (de forma fraudulenta) su identidad mediante la aportación correcta de las credenciales de acceso, habiendo obtenido los datos personales de las víctimas a través de técnicas de ingeniería social. Pretender que Vodafone pruebe la identidad de los solicitantes una vez que estos han facilitado de forma válida su usuario y contraseña supone una suerte de prueba diabólica que no se puede exigir a Vodafone.

Subsidiariamente, y para el caso de que la Agencia entendiera que Vodafone ha infringido el artículo 6.1 del RGPD, no puede apreciarse la existencia de culpabilidad en las infracciones imputadas a Vodafone y, en consecuencia, no puede imponerse a la misma sanción alguna.

Con carácter subsidiario, en el caso de que esta Agencia entendiera que Vodafone sí ha infringido el artículo 6.1 del RGPD, no procede la imposición de sanción alguna a mi mandante por los motivos que se verán a continuación.

El artículo 28.1 de la Ley 40/2015, de 1 de octubre, de Régimen Jurídico del Sector Público, regula el principio de culpabilidad, en virtud del cual es necesario que el supuesto infractor sea responsable de la infracción cometida. Así, dicho artículo dispone que: "Sólo podrán ser sancionadas por hechos constitutivos de infracción administrativa las personas físicas y jurídicas, así como, cuando una Ley les reconozca capacidad de obrar, los grupos de afectados, las uniones y entidades sin personalidad jurídica y los patrimonios independientes o autónomos, que resulten responsables de los mismos a título de dolo o culpa". Por ello, en el caso de que la

Agencia entendiera que la conducta de Vodafone es constitutiva la infracción indicada en el Acuerdo de Inicio, es claro que no concurre en la conducta de Vodafone culpabilidad ninguna, ni a título de dolo ni a título de culpa.

Vodafone ha empleado la diligencia que le era exigible para garantizar la licitud del tratamiento de los datos personales de su cliente y evitar el duplicado de tarjetas SIM por parte de terceros distintos al titular. Esto es precisamente lo que ocurre en el presente supuesto, y es que en ningún caso el duplicado de las tarjetas SIM del cliente de Vodafone puede suponer la consideración de que Vodafone ha obrado culposamente. En efecto, todas las actuaciones de la misma han ido siempre dirigidas al establecimiento y supervisión de medidas técnicas y organizativas tendentes a garantizar la seguridad de los datos personales de sus clientes.

Vodafone no sólo ha implementado políticas de seguridad para hacer frente a los duplicados fraudulentos de tarjetas SIM, sino que ha ido actualizando dichas medidas de seguridad y envía comunicados y alertas a sus tiendas y agentes para asegurarse de que éstas se mantienen alerta.

En consecuencia, Vodafone ha actuado en todo momento cumpliendo con la diligencia debida que le es exigible, no pudiendo imputársele culpabilidad alguna. Por ello, teniendo en cuenta la especial naturaleza del Derecho administrativo sancionador que determina la imposibilidad de imponer sanciones sin tener en cuenta la culpabilidad y la diligencia, o los errores que hayan podido determinar el incumplimiento de una obligación legal, esta parte mantiene la improcedencia de la imposición de sanción alguna.

En su Acuerdo de Inicio, la Agencia entiende que, en relación con la supuesta infracción del artículo 6.1 del RGPD, concurrirían los siguientes agravantes y atenuantes: 1. Agravantes: Toda infracción anterior cometida por el responsable o el encargado del tratamiento. Así como la vinculación de la actividad de Vodafone con la realización de tratamientos de datos de carácter personal. Mi mandante discrepa respetuosamente de los agravantes indicados en el Acuerdo de Inicio por los motivos que se expondrán a continuación y por los cuales entiende que la sanción – de ser impuesta – debe modularse a la baja.

I. Toda infracción anterior cometida por el responsable o el encargado del tratamiento. Es relevante destacar que los procedimientos sancionadores a los que hace referencia la Agencia para fundamentar este agravante; EXP202204287, EXP202203914 y EXP202203916, son relativos a clientes de Vodafone que no son clientes de la marca Lowi y cuyos duplicados SIM se tramitaron por canales diferentes al del caso aquí analizado, la app Mi Lowi. En este sentido, se considera que los mismos, al no ser análogos al supuesto analizado en este sancionador, no deben de ser aplicados como agravante.

II. La vinculación de la actividad de Vodafone con la realización de tratamientos de datos de carácter personal. Efectivamente, existe una vinculación entre la actividad de Vodafone y el tratamiento de datos personales de sus clientes que realiza para llevar a cabo la correcta prestación de los servicios contratados y atender las solicitudes y peticiones que éstos realicen. La Agencia hace referencia a la existencia de imprudencia cuando un responsable del tratamiento no se comporta con la diligencia exigible debiendo insistirse en el rigor y el exquisito cuidado para ajustarse a las

prevenciones legales al respecto. Prueba del especial cuidado y cautela aplicada en el tratamiento de datos personales que lleva a cabo mi representada, son todas las medidas de seguridad implementadas y que se detallan en la Alegación primera, además de la continua revisión de sus políticas y cumplimiento de las mismas. Por lo que este factor, no debe ser tenido en cuenta como agravante a la hora de graduar la sanción.

Además, entendemos que también deberían tomarse en consideración las siguientes atenuantes: I. Vodafone procedió a solventar la incidencia objeto de reclamación de forma efectiva en cuanto tuvo conocimiento de los hechos (art. 83.2 c del RGPD), no existiendo un carácter continuado en el tratamiento ilícito y procedimiento a regularizar la situación irregular de forma diligente Tal y como se ha manifestado, el duplicado SIM fue entregado el 7 de febrero de 2023 a las 11:35 horas, sin embargo, el duplicado SIM fue bloqueado por el Departamento de Fraude a las horas de que se activara, en concreto a las 20:29 horas del mismo día 7 de febrero. A este respecto se adjunta captura de pantalla de los sistemas internos de mi representada donde consta el bloqueo del duplicado SIM en cuestión. Asimismo, el Departamento de Fraude procedió a la activación del check de víctima de fraude en los sistemas internos de Vodafone, incluyendo los datos personales del reclamante en la agrupación de fraude y en los ficheros de prevención de Vodafone, activando medidas de seguridad adicionales sobre sus datos para evitar que se pueda producir un caso similar en el futuro. Sobre este respecto, se vuelve a aportar captura de pantalla de los sistemas internos de Vodafone, donde figura la ficha de cliente del reclamante. Por todo ello mi representada procedió a solventar correctamente la incidencia manifestada a las pocas horas de que se produjera, realizando todos los trámites necesarios para solventarla.

II. El grado de responsabilidad del responsable del tratamiento, habida cuenta de las medidas técnicas u organizativas que hayan aplicado en virtud de los artículos 25 y 32 del RGPD Tal y como se ha expuesto, Vodafone ha implementado medidas técnicas y organizativas adecuadas para el riesgo generado por mi mandante, esto es, tendentes a asegurar que quien solicita el duplicado o cambio de una tarjeta SIM es el titular de la línea.

Por lo tanto, siguiendo lo establecido en el art. 45.4 i) de la Ley Orgánica 15/1999, de 13 de diciembre, de Protección de Datos de Carácter Personal, mi representada ha acreditado "que con anterioridad a los hechos constitutivos de infracción la entidad imputada tenía implantados procedimientos adecuados de actuación en la recogida y tratamiento de los datos de carácter personal, siendo la infracción consecuencia de una anomalía en el funcionamiento de dichos procedimientos no debida a una falta de diligencia exigible al infractor".

III. El grado de cooperación con la autoridad de control con el fin de poner remedio a la infracción y mitigar los posibles efectos adversos de la infracción Mi mandante también entiende que su grado de cooperación con la Agencia durante las actuaciones previas de inspección ha sido alto.

IV. Cualquier otro factor agravante o atenuante aplicable a las circunstancias del caso, como los beneficios financieros obtenidos o las pérdidas evitadas, directa o indirectamente, a través de la infracción Vodafone no ha obtenido ningún tipo de

beneficio o evitado pérdidas a raíz de la duplicación fraudulenta de tarjetas SIM, sino todo lo contrario. En este sentido, la actividad criminal llevada a cabo por los estafadores y ciberdelincuentes también ha supuesto un perjuicio reputacional para mi mandante y una defraudación de sus políticas de seguridad. Por todo lo anterior, a efectos de demostrar la ausencia de la infracción, así como la falta de culpabilidad de mi representada en el presente expediente, o, en su caso, modular a la baja la sanción propuesta por la Agencia, esta parte solicita que se tenga en consideración lo expuesto en estas y anteriores alegaciones, teniendo en especial consideración que mi mandante ha actuado en todo momento con la debida diligencia, siguiendo la Política de Seguridad de Lowi y tomando todas las medidas necesarias para solventar correctamente la incidencia con la mayor brevedad posible. En virtud de todo lo anterior, solicito el sobreseimiento del expediente con el consiguiente archivo de las actuaciones, por no haberse cometido ninguna de las infracciones imputadas. Subsidiariamente, que en caso de imponerse alguna sanción se imponga en cuantía mínima.>>

OCTAVO: Con fecha 6 de marzo de 2024, el instructor del procedimiento acordó practicar las siguientes pruebas: “1. Se dan por reproducidos a efectos probatorios la reclamación interpuesta por **A.A.A.** y su documentación, los documentos obtenidos y generados durante la fase de admisión a trámite de la reclamación, y el informe de actuaciones previas de investigación que forman parte del procedimiento AI/00227/2023. 2. Asimismo, se da por reproducido a efectos probatorios, las alegaciones al acuerdo de inicio del procedimiento sancionador referenciado, presentadas por **VODAFONE ESPAÑA, S.A.U.**, y la documentación que a ellas acompaña. El resultado de estas pruebas podrá dar lugar a la realización de otras.”

NOVENO: Con fecha 21 de marzo de 2024, Vodafone dentro del plazo concedido en el período de pruebas, realiza las siguientes alegaciones: <<Vodafone exige a su colaborador logístico la verificación de la identidad de la persona a la que entrega el duplicado SIM.

Es relevante destacar, tal y como mi representada ha señalado en las alegaciones presentadas al Acuerdo de Inicio, que Vodafone adopta unas robustas y efectivas medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo asociado a cada uno de los trámites solicitados por sus clientes.

En lo que respecta al proceso de entrega del duplicado SIM, tal y como se ha indicado anteriormente a esta Agencia, Lowi exige a su colaborador logístico, en el caso que nos ocupa Correos Express, que ejecute la entrega de dicho duplicado mediante un mecanismo de “entrega exclusiva”, es decir, que la persona que recoge el duplicado debe acreditar su identidad mediante la aportación de su DNI, NIE o pasaporte al transportista, quien realizará una verificación visual para comprobar que los datos ahí recogidos coinciden con los de la persona a la que va dirigido el paquete.

Con respecto al caso que motiva el presente Acuerdo de Inicio, mi representada ha comprobado en sus sistemas internos que en la entrega del duplicado SIM, el cual fue realizado sin el consentimiento de la reclamante, fue categorizada como “89 Entrega Exclusiva”, tal y como se evidenció en la captura de pantalla aportada de los sistemas internos de mi representada, por lo que el transportista tuvo que solicitar el DNI a la persona receptora del mismo, realizando una verificación visual del documento y

comprobando que la información ahí recogida coincidía con la de la titular, el reclamante.

Lowi tiene contratados con el operador logístico CEVA Logistics ("CEVA"), un servicio de entrega exclusiva por el cual se establece que todos los envíos calificados internamente por Lowi con el número 89 deberán seguir un método de entrega exclusiva.

Desde CEVA se trabaja con distintas empresas de transportes para la entrega de estos duplicados, en este caso Correos Express, y se traslada e identifica las entregas que deben seguir un método de entrega exclusiva.

El método de entrega exclusiva establece que el transportista tiene que solicitar el DNI del receptor, introducir su número de DNI en el sistema de gestión de envíos al cual tiene acceso, y que de manera automática verificará que los datos aportados coinciden con los registrados en la orden de envío, es decir, con los del titular. En caso de que los datos no coincidan, la entrega no podrá efectuarse.

Por lo que, en este caso el transportista tuvo que verificar la identidad del receptor del duplicado SIM, solicitando su DNI e introduciendo los datos ahí contenidos en el sistema de gestión de envíos, el cual comprobó automáticamente que sus datos coincidían con los registrados en la orden de envío remitida por mi representada.

Sobre este respecto, mi representada aporta el certificado emitido por CEVA, en el que se recoge cómo Vodafone tiene contratado con esta empresa el servicio de entrega exclusiva, y donde se especifica que: Dicho certificado se aporta como Documento número 1 >>.

DÉCIMO: Con fecha 8 de abril de 2024, se emitió por el instructor del expediente la propuesta de resolución y fue notificada electrónicamente el día 10 del mismo mes y año y en la misma se proponía: "Que por la Directora de la Agencia Española de Protección de Datos se sancione a VODAFONE ESPAÑA, S.A.U., con NIF A80907397, por una infracción del Artículo 6.1 del RGPD, tipificada en el Artículo 83.5.a) del RGPD, con una multa de 200.000 € (doscientos mil euros)".

UNDECIMO: Con fecha 11 de abril de 2024, solicitó Vodafone ampliación de plazo para formular alegaciones a la propuesta de resolución y el día 16 del mismo mes y año le fue concedido y el día 30 de abril de 2024 presentó las siguientes alegaciones:

PRIMERA. - La parte reclamada ha actuado de forma diligente en la medida en la que tiene implementados los procesos necesarios para identificar correctamente a sus clientes, siendo la adopción de medidas técnicas y organizativas una obligación que no es absoluta.

La parte reclamada sostiene que ha implementado medidas técnicas y organizativas adecuadas para identificar a sus clientes y evitar fraudes en la gestión de duplicados de tarjetas SIM. A pesar de estas medidas, la parte reclamada indica que los defraudadores pueden superar la seguridad mediante técnicas ilícitas para obtener datos confidenciales, lo que no indica una insuficiencia en las políticas, sino una obtención ilegal de información fuera de su control.

Asimismo, señala que tanto la Audiencia Nacional como la Agencia reconocen que la obligación de adoptar medidas de seguridad no es absoluta, sino que es una obligación de medios. En consecuencia, siempre existirá un riesgo residual en el tratamiento de datos personales, incluso con medidas robustas.

De igual forma, afirma que ha acreditado la implementación de un procedimiento riguroso para verificar la identidad de los solicitantes de duplicados SIM, tanto a través de su app como mediante la entrega exclusiva con verificación de DNI por parte de transportistas. Sin embargo, sostiene que los defraudadores pudieron superar estas medidas mediante ingeniería social y obtención ilícita de datos personales del reclamante.

A pesar de los esfuerzos para mejorar continuamente las políticas de seguridad, indica que no puede controlar las técnicas fraudulentas utilizadas por terceros antes de la solicitud de duplicado. Además, afirma que ha reforzado sus medidas de seguridad a lo largo de los años, incluyendo mecanismos de doble autenticación y controles más estrictos en los cambios de datos y solicitudes de duplicados.

Por tanto, la parte reclamada manifiesta que no se puede considerar que no haya verificado correctamente la identidad del solicitante del duplicado SIM, ya que el fraude ocurrió fuera de su control y cumplió con sus políticas de seguridad en todo momento.

SEGUNDA. - Estamos ante un tercero cuyo propósito es, mediante una actividad delictiva, superar dichas medidas de seguridad.

La parte reclamada sostiene que el acceso a los datos personales, como la tarjeta SIM, se produjo mediante una actividad delictiva organizada, no por fallos en su sistema. Afirman que los delincuentes, a menudo en organizaciones criminales, usan técnicas fraudulentas previas a la solicitud de cambio de SIM para superar los protocolos de seguridad.

A su juicio ello queda acreditado en las múltiples cancelaciones de solicitudes de duplicado SIM en febrero de 2023, detectadas por los equipos de Fraude y Atención al Cliente. Afirma que la Agencia reconoce que el defraudador logró eludir controles usando datos obtenidos ilícitamente.

La parte reclamada resalta que, aunque modifica continuamente su política de seguridad, las organizaciones criminales también evolucionan, haciendo imposible prevenir todos los fraudes. En este caso, el defraudador conocía los datos necesarios para modificar credenciales y solicitar un duplicado SIM, superando la política de seguridad de la reclamada.

Por tanto, la parte reclamada afirma que actuó conforme a sus políticas, verificando correctamente la identidad del solicitante del duplicado SIM y no pudiendo detectar la intención fraudulenta.

TERCERA. - La realización de un duplicado SIM no conlleva el acceso a información bancaria, contraseñas, dirección de correo electrónico, etc., de los clientes de La parte reclamada, sino a los servicios de móvil e internet que pudieran tener contratados.

La parte reclamada sostiene que la realización de un duplicado SIM no conlleva el acceso a información bancaria, contraseñas, o dirección de correo electrónico de los clientes, sino únicamente a los servicios de móvil e internet contratados. Afirma que la Agencia, en su Propuesta de Resolución, reconoce que la emisión de duplicados de la tarjeta SIM no es suficiente para realizar operaciones bancarias, ya que el estafador debe suplantar la identidad del titular ante la entidad financiera. En consecuencia, la tarjeta SIM solo permite acceder al servicio móvil, sin implicar acceso a información bancaria o contraseñas.

En este sentido, explica que el proceso fraudulento se divide en dos fases:

- Previa al duplicado: El defraudador debe obtener información del cliente de fuentes ajenas a la reclamada para superar las políticas de seguridad mediante la suplantación de identidad.
- Posterior al duplicado: El defraudador tiene acceso únicamente al servicio contratado por el cliente, sin obtener información bancaria o contraseñas como consecuencia directa del duplicado.

Para ello, se basa en la respuesta de la entidad bancaria, según la cual, además de la clave única enviada por SMS, se requiere el acceso a la aplicación del banco mediante usuario y contraseña. Según su postura, ello demuestra que el duplicado SIM no es suficiente para acceder a cuentas bancarias sin la obtención de credenciales adicionales.

Por tanto, afirma que la parte reclamada puede ser responsable solo de las medidas de seguridad relacionadas con la verificación de la identidad del solicitante del duplicado SIM, no de la suplantación de identidad ni del acceso a cuentas bancarias a través de aplicaciones de entidades de crédito.

CUARTA. - No puede apreciarse la existencia de culpabilidad en las infracciones imputadas a La parte reclamada y, en consecuencia, no puede imponerse a la misma sanción alguna.

La parte reclamada considera necesario contestar a las afirmaciones de la Agencia en su Propuesta de Resolución en este aspecto ya alegado frente al acuerdo de inicio.

Afirma que la AEPD no considera todas las medidas que existían en el momento de los hechos objeto de sanción ni las mejoras que la parte reclamada ha implementado, obrando con la máxima diligencia exigible. En este sentido, la parte reclamada se remite a las medidas técnicas y organizativas indicadas en la primera alegación.

Por otro lado, la AEPD sostiene que el principio de proactividad transfiere a la parte reclamada la obligación de cumplir con la normativa y demostrar dicho cumplimiento. Indica que ha cubierto ampliamente este aspecto, aportando los procesos implementados y las interacciones en sus sistemas que evidencian el seguimiento de los procedimientos pertinentes.

Por lo tanto, manifiesta que actuó con la diligencia debida, implementando las medidas técnicas y organizativas necesarias a pesar de que la Agencia defiende que existe

dolo o culpa únicamente observando el resultado de los hechos, sin considerar todas las medidas de seguridad implementadas para evitar el fraude. Señala que esta lógica impone a la parte reclamada la obligación de evitar todos los fraudes, convirtiéndose en una obligación absoluta, no de medios, lo que contradice lo dispuesto por la Audiencia Nacional.

Finalmente, la parte reclamada discrepa de la afirmación de la Autoridad de que los duplicados SIM fraudulentos se producen a gran escala. Sostiene que las medidas implementadas son efectivas, ya que los casos de fraude son muy concretos y reducidos, con estafadores que previamente obtienen información y logran superar las medidas de seguridad. Indica que cuenta con medidas de seguridad suficientes, aunque reconoce que el riesgo cero no existe, y esto no implica que las medidas sean insuficientes.

QUINTA. - Subsidiariamente, y para el caso de que la Agencia entendiera que La parte reclamada ha infringido el artículo 6.1 del RGPD, no puede apreciarse la existencia de culpabilidad en las infracciones imputadas a la parte reclamada y, en consecuencia, no puede imponerse a la misma sanción alguna.

La parte reclamada señala que el artículo 28.1 de la Ley 40/2015, de 1 de octubre, de Régimen Jurídico del Sector Público, regula el principio de culpabilidad, indicando que solo pueden ser sancionadas las personas físicas y jurídicas responsables de infracciones a título de dolo o culpa. Así, si la Agencia considerara que la conducta de la parte reclamada es constitutiva de la infracción, afirma que no concurre en dicha conducta culpabilidad alguna, ni a título de dolo ni de culpa.

Apoyándose en ciertas sentencias, manifiesta que para la exculpación no basta con invocar la ausencia de culpa, sino que es preciso demostrar la diligencia exigible. Indica que enfrenta prácticas delictivas que evolucionan con el tiempo, llevadas a cabo por estafadores y ciberdelincuentes, a menudo en organizaciones criminales. Estos delincuentes utilizan técnicas previas a la solicitud de cambio de SIM para obtener datos personales y superar los protocolos de seguridad. Manifiesta que hasta cinco intentos de duplicado de tarjeta SIM fueron cancelados por sus equipos de Fraude y Atención al Cliente, como se observa en los Hechos Probados de la Propuesta de Resolución.

Afirma que, una vez superadas las medidas de seguridad de la operadora, los delincuentes continúan con sus actividades delictivas para eludir las medidas de seguridad de las entidades bancarias. Por tanto, considera necesario determinar si ha empleado la diligencia exigible para garantizar la licitud del tratamiento de datos personales y evitar el duplicado de tarjetas SIM por parte de terceros.

Sostiene que el duplicado de tarjetas SIM no implica culpabilidad alguna. Afirma que todas sus actuaciones han estado dirigidas a establecer y supervisar medidas técnicas y organizativas para garantizar la seguridad de los datos personales de sus clientes.

Además, indica que ha implementado y actualizado constantemente sus políticas de seguridad, enviando comunicados y alertas a sus tiendas y agentes. En los casos en los que los estafadores han logrado defraudar el sistema, la parte reclamada manifiesta que ha reaccionado de diversas formas que han sido acreditadas.

Por todo ello, la parte reclamada afirma que ha actuado cumpliendo con la diligencia debida exigible, no pudiendo imputársele culpabilidad alguna. Indica que, considerando la especial naturaleza del Derecho administrativo sancionador, resulta improcedente la imposición de sanción alguna.

SEXTA. - Subsidiariamente, y para el caso de que la Agencia entienda que ha existido infracción y deba imponerse una sanción a La parte reclamada, deberán tenerse en cuenta las siguientes circunstancias agravantes y atenuantes.

En este sentido, la parte reclamada discrepa de los motivos expuestos por la Agencia para desestimar la reducción de la sanción por los motivos que se incluyen a continuación.

Sobre los agravantes aplicados por la Agencia a la hora de evaluar la sanción, la parte reclamada se reitera en lo dispuesto en las Alegaciones al Acuerdo de Inicio:

- Indica que los procedimientos sancionadores a los que hace referencia la Agencia (EXP202204287, EXP202203914 y EXP202203916) se refieren a clientes que no son de la marca la parte reclamada y cuyos duplicados SIM se tramitaron por canales distintos a la app. Por tanto, considera que estos casos no son análogos y no deben aplicarse como agravantes.
- Reconoce la vinculación entre su actividad y el tratamiento de datos personales para prestar servicios y atender solicitudes de sus clientes. Sin embargo, destaca que todas las medidas de seguridad implementadas y detalladas en la alegación Primera demuestran el especial cuidado en el tratamiento de datos, por lo que este factor no debe considerarse como agravante.

Sobre los atenuantes no aplicados por la Agencia a la hora de evaluar la sanción, la parte reclamada entiende que deberían tomarse en consideración las siguientes:

- Que procedió a solventar la incidencia objeto de reclamación de forma efectiva en cuanto tuvo conocimiento de los hechos. La parte reclamada manifiesta que el duplicado SIM fue bloqueado por el Departamento de Fraude pocas horas después de su activación el 7 de febrero de 2023. Asimismo, se activaron medidas de seguridad adicionales para evitar futuros casos similares. Estas acciones demuestran que la incidencia fue resuelta de manera diligente.
- El grado de responsabilidad del responsable del tratamiento, habida cuenta de las medidas técnicas u organizativas aplicadas. La parte reclamada indica que ha implementado medidas técnicas y organizativas adecuadas para el riesgo generado, asegurando que quien solicita modificaciones o duplicados de tarjetas SIM es el titular de la línea. Manifiesta que la falta de identificación del estafador no es reprochable, ya que esta tarea corresponde a las Fuerzas y Cuerpos de Seguridad del Estado, con quienes colabora activamente.
- El grado de cooperación con la autoridad de control con el fin de poner remedio a la infracción y mitigar los posibles efectos adversos de la infracción. La parte reclamada señala que ha implementado nuevas medidas y controles para reducir al máximo el riesgo inherente al tratamiento de datos, y ha reaccionado ante fraudes dirigidos hacia cuatro frentes: clientes afectados, agentes y

empleados, colaboración con autoridades, y terceros como entidades de crédito.

- Cualquier otro factor agravante o atenuante aplicable a las circunstancias del caso. La parte reclamada manifiesta que no ha obtenido ningún beneficio financiero ni evitado pérdidas a raíz de la duplicación fraudulenta de tarjetas SIM, sino que ha sufrido perjuicios reputacionales y defraudación de sus políticas de seguridad.

Por todo lo anterior, la parte reclamada solicita que se considere lo expuesto en estas y anteriores alegaciones para demostrar la ausencia de infracción y la falta de culpabilidad, o para modular a la baja la sanción propuesta por la Agencia, destacando que ha actuado con la debida diligencia y ha seguido su Política de Seguridad para solventar la incidencia con la mayor brevedad posible.

De las actuaciones practicadas en el presente procedimiento y de la documentación obrante en el expediente, han quedado acreditados los siguientes:

HECHOS PROBADOS

PRIMERO. - Obra en el expediente, que se realizaron los siguientes duplicados SIM:

El 2 de febrero de 2023 se solicita un duplicado SIM desde la app de mi Lowi a las 13:58 horas, donde para acceder ha tenido que aportar previamente sus credenciales (usuario y contraseña), y el cual es cancelado el 3 de febrero de 2023 a las 10:55 horas, tras haber contactado un Agente de Atención al Cliente de Lowi con el reclamante.

El 6 de febrero de 2023 a las 15:45 horas, se solicita una petición de un segundo duplicado SIM a través de la app de Mi Lowi, después de acreditarse a través de credenciales válidas. Este duplicado SIM es procesado.

El 7 de febrero de 2023 a las 20:29 horas, se solicita un duplicado SIM a través de la app de mi Lowi, siendo cancelado el 8 de febrero de 2023 a las 14:48 horas.

El 9 de febrero de 2023 a las 17:12 horas se tramita la solicitud de un duplicado SIM a través de la App de Lowi, Este pedido es cancelado el 10 de febrero de 2023 a las 14:52 horas.

El 13 de febrero de 2023 a las 13:43 horas, se solicita un duplicado a través de la App de Lowi. Este pedido figura cancelado el 14 de febrero de 2023 a las 14:37 horas, sin embargo, el reclamante contacta con los servicios de Atención al Cliente de Lowi, y comenta los motivos y dificultades que tiene para activar su tarjeta SIM por lo que el Agente, después de pasar la política de seguridad correctamente, se la activa.

El 16 de febrero de 2023 a las 16:36 horas, se solicita un duplicado desde la app de mi Lowi, este pedido es cancelado el mismo día y a las pocas horas de su solicitud, exactamente a las 20:26 horas.

Consta que el duplicado efectuado en fecha 6 de febrero de 2023 ha sido calificado como fraudulento por parte del Departamento de Fraude de Lowi.

SEGUNDO. - Consta según manifiesta Vodafone en su escrito de fecha 5 de junio de 2023 que de todas las llamadas realizadas al Servicio de Atención al Cliente, excepto la realizada el día 6 de febrero de 2023, para el cambio de dirección de correo electrónico no pudieron ser completadas con éxito, ya que el solicitante no aportó correctamente toda la información que prevé la Política de Seguridad para la verificación de la identidad (en particular, la comprobación de la cuenta bancaria vinculada al servicio).

Queda acreditado, que la llamada realizada a la marca Lowi de Vodafone en fecha 6 de febrero de 2023 consiguió la modificación de la dirección de correo electrónico del reclamante, vinculada al acceso a su área privada, y solicitó dicho tercero un duplicado de la tarjeta SIM del reclamante y se facilitó por la tercera persona para realizar la entrega del pedido del duplicado de la tarjeta SIM un domicilio distinto del que figuraba en el registro de Vodafone para la facturación del reclamante.

Queda acreditado, que la parte reclamada no comprobó si previamente la línea estaba bloqueada o defectuosa, como recomienda su propia política de privacidad.

Obra en el expediente, que el duplicado SIM es entregado el día 7 de febrero de 2023 en la dirección postal facilitada por el tercero, domicilio diferente al del titular reclamante.

FUNDAMENTOS DE DERECHO

I

Competencia

De acuerdo con los poderes que el artículo 58.2 del Reglamento (UE) 2016/679 (Reglamento General de Protección de Datos, en adelante RGPD), otorga a cada autoridad de control y según lo establecido en los artículos 47, 48.1, 64.2 y 68.1 de la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales (en adelante, LOPDGDD), es competente para iniciar y resolver este procedimiento la Directora de la Agencia Española de Protección de Datos.

Asimismo, el artículo 63.2 de la LOPDGDD determina que: *“Los procedimientos tramitados por la Agencia Española de Protección de Datos se registrarán por lo dispuesto en el Reglamento (UE) 2016/679, en la presente ley orgánica, por las disposiciones reglamentarias dictadas en su desarrollo y, en cuanto no las contradigan, con carácter subsidiario, por las normas generales sobre los procedimientos administrativos.”*

II

Contestación a las alegaciones presentadas a la Propuesta de Resolución

Se procede a dar respuesta a las mismas según el orden expuesto por Vodafone.

PRIMERA. - La parte reclamada ha actuado de forma diligente en la medida en la que tiene implementados los procesos necesarios para identificar correctamente

a sus clientes, siendo la adopción de medidas técnicas y organizativas una obligación que no es absoluta.

A pesar de que la parte reclamada afirma haber actuado de forma diligente en el presente caso, puede afirmarse que existieron una serie de irregularidades, dado que la parte reclamada no comprobó si previamente la línea estaba bloqueada o defectuosa, como recomienda su propia política de seguridad tal y como queda reflejado en el hecho probado segundo de la presente resolución.

La parte reclamada también manifiesta en su contestación a las actuaciones previas de investigación de esta Agencia lo siguiente:

“Es relevante destacar que el duplicado efectuado en fecha 6 de febrero de 2023 ha sido calificado como fraudulento por parte del Departamento de Fraude de Lowi. En la ficha del cliente que consta en los sistemas internos de mi representada, figura un aviso en el que se indica que no deben realizarse ninguna modificación de datos si se llama desde un número dentro del parque contratado [sic, se entiende que debería decir “fuera del parque contratado”], con el fin de evitar que casos como estos puedan repetirse. La medida, tal y como puede apreciarse en las grabaciones de las interacciones ejecutadas el 22 y 27 de febrero de 2023, y aportadas en el Documento número 1, evita que se produzcan intentos de duplicados SIM fraudulentos. Se adjunta pantallazo de la ficha de cliente de reclamante donde figura el aviso correspondiente.”

En el mencionado pantallazo aparece (esquina superior derecha) la palabra de seguridad que la parte reclamante estableció en la llamada de 7 de febrero, pero que no fue solicitada en varias llamadas, realizadas tanto por la propia parte reclamante como por el otro u otros individuos no autorizados, los días 9, 10, 13, 14, 15 y 16 de febrero, como puede comprobarse en las grabaciones que forma parte del presente expediente y a las que hace referencia el hecho probado primero.

Asimismo, el mencionado aviso de fraude en el sistema de Lowi tampoco fue eficaz en la llamada del día 16 de febrero, en la que el otro u otros consigue de nuevo modificar las credenciales de acceso

En resumen esta alegación no puede prosperar, porque ha quedado constatado que la parte reclamada no ha cumplido con su propia política de seguridad. Por lo demás, la medida consistente en el aviso a la que hace referencia, pone de manifiesto la falta de diligencia de la misma puesto que, a pesar de la adopción de dichas medidas, el tratamiento ilícito de los datos personales de la parte reclamante se produjo igualmente dado que se desprende que no se atendió debidamente al mismo en las solicitudes fraudulentas.

SEGUNDA. - Estamos ante un tercero cuyo propósito es, mediante una actividad delictiva, superar dichas medidas de seguridad.

Hace referencia Vodafone, para su descargo, al conjunto de medidas de seguridad que ha adoptado, que, las medidas implantadas son las mínimas exigibles a cualquier organización con las características y en el contexto en el que actúa una operadora de telecomunicaciones.

Tal y como se ha probado, la parte reclamada ha incumplido con su propia política de seguridad por lo que la alegación de la adopción de las medidas de seguridad carece de virtualidad, al no hacerles efectivas mediante su aplicación adecuada.

La intervención fraudulenta de un tercero, lo que ha revelado es el deficiente análisis de los riesgos, así como la insuficiente implantación, revisión y control de las medidas de seguridad por parte de la operadora. Tercero ajeno al titular de los datos ha superado las medidas de seguridad establecidas por Vodafone. Esto nos muestra que la identificación del titular de los datos no se producía con las suficientes garantías, independientemente de que la identificación se realizara por el propio titular o por un tercero de forma fraudulenta.

Al respecto hay que señalar que precisamente el que nos encontremos ante el fraude de un tercero hace que sea necesario asegurarse que la persona a la que se expide el duplicado de la tarjeta SIM es quien realmente dice ser y deben adoptarse las medidas necesarias de prevención adecuadas para verificar la identidad de una persona cuyos datos van a ser objeto de tratamiento tal y como se reconoce en el Fundamento Jurídico Séptimo de la SAN, SCA, de 5 de mayo de 2021 ("Por otro lado, en cuanto al hecho de que nos encontramos ante el fraude de un tercero, como dijimos en la SAN de 3 de octubre de 2013 (Rec. 54/2012) -: "*Precisamente por eso, es necesario asegurarse que la persona que contrata es quien realmente dice ser y deben adoptarse las medidas de prevención adecuadas para verificar la identidad de una persona cuyos datos personales van a ser objeto de tratamiento...*").

A lo largo del presente procedimiento Vodafone ha manifestado reiteradamente que los duplicados fraudulentos de las tarjetas se han producido tras haber superado los defraudadores su política de seguridad. Considera que es inevitable que a pesar de la existencia de la política de seguridad pueda haber casos en los que a través de ciertos mecanismos dicha política de seguridad pueda ser sobrepasada de forma fraudulenta sin que por ello pueda existir reproche a Vodafone.

Sin embargo, la mera existencia de una política de seguridad no puede justificar una vulneración del principio de licitud previsto del artículo 6.1 del RGPD. Además de existir, estas medidas deben resultar efectivas y el responsable del tratamiento debe de garantizar que se cumplan estrictamente en todo momento. En caso contrario, las medidas adoptadas no cumplen su misión y puede conllevar tratamientos ilícitos como ocurre en el presente caso.

Por lo tanto, la cuestión aquí no radica en el nivel de sofisticación del ataque delictivo del tercero, sino en el incumplimiento de las propias medidas de seguridad que permitieron el tratamiento ilícito de datos personales. La parte reclamada no puede exonerar su responsabilidad apelando a la existencia de medidas mínimas cuando el fallo estuvo en la aplicación de esas medidas, permitiendo una infracción de la licitud del tratamiento.

TERCERA. - La realización de un duplicado SIM no conlleva el acceso a información bancaria, contraseñas, dirección de correo electrónico, etc., de los clientes de la parte reclamada, sino a los servicios de móvil e internet que pudieran tener contratados.

La parte reclamada manifiesta que la emisión de los duplicados de la tarjeta SIM no es suficiente para realizar operaciones bancarias en nombre de los titulares, puesto que, para completar la estafa, es necesario que un tercero “suplante la identidad” del titular de los datos ante la entidad financiera. Sin embargo, dicha afirmación no exime de responsabilidad a la parte reclamada, puesto que si bien la obtención de duplicación de una tarjeta SIM no implica directamente la posibilidad de acceder a dichos datos ni la de realizar operaciones bancarias en nombre de los mismos, lo cierto es que la simple utilización de una tarjeta SIM por un tercero no autorizado implica ya de por sí una vulneración del principio de licitud pues un tercero está tratando datos sin base legal alguna. Debe de tenerse en cuenta, además que la posesión de un duplicado de tarjeta cuando el suplantador posee datos adicionales, puede producir efectos más gravosos, como la realización de operaciones financieras no deseadas, como acaeció en el caso de la parte reclamante.

Por dicha razón, facilitar un duplicado de tarjeta es un proceso en donde la diligencia prestada por los operadores es fundamental para evitar este tipo de estafas y vulneraciones del RGPD. Diligencia que se traduce en el cumplimiento de su propia Política de seguridad para garantizar que el tratamiento de datos sea conforme al RGPD, lo cual, en el caso que nos ocupa y tal como ha reconocido la parte reclamada, no ha tenido lugar.

Vodafone insiste respecto del grado de responsabilidad que, en su caso, pueda achacárseles, no puede hacerse depender de una actuación de un tercero que escapa su control, esto es: las medidas de seguridad implementadas por una u otra entidad bancaria o incluso el hecho de que el afectado disponga o no de banca electrónica.

En relación con esta alegación, amén de lo ya indicado anteriormente, el grado de responsabilidad cae dentro de su ámbito y no de terceros, debiendo señalar que la SAN -Sala Contencioso Administrativo- de 5 de mayo de 2021, establece que: *“Por otro lado, en cuanto al hecho de que nos encontramos ante el fraude de un tercero, como dijimos en la SAN de 3 de octubre de 2013 (Rec. 54/2012)-: “ Precisamente por eso, es necesario asegurarse que la persona que contrata es quien realmente dice ser y deben adoptarse las medidas de prevención adecuadas para verificar la identidad de una persona cuyos datos personales van a ser objeto de tratamiento”.*

En este sentido, conviene señalar que en el presente caso no se trata de valorar la actuación del banco o cualquier otra entidad externa, sino de examinar cómo la parte reclamante permitió un tratamiento de datos personales sin seguir los procedimientos establecidos.

La actuación de sus agentes no escapa a su control, ya que estos actúan en nombre de la parte reclamada y, por tanto, son responsables de cumplir con las políticas de seguridad. En el presente caso, la parte reclamada no ha cumplido con su propia política de seguridad, lo que facilitó el acceso no autorizado a los datos personales del reclamante, lo cual demuestra que la infracción no depende un tercero, sino de una falta de cumplimiento dentro de la organización.

Por tanto, la responsabilidad no puede ser desplazada hacia elementos externos. La parte reclamada es directamente responsable del comportamiento de su personal y de

asegurar que los protocolos de seguridad se apliquen correctamente en cada caso, sin excepción.

CUARTA. - No puede apreciarse la existencia de culpabilidad en las infracciones imputadas a la parte reclamada y, en consecuencia, no puede imponerse a la misma sanción alguna.

Por otro lado, y estrictamente en cuanto a la negligencia en la actuación de Vodafone, cabe señalar que la SAN -Sala Contencioso-Administrativo- 392/2015, de 17 de noviembre que en su Fundamento Jurídico Tercero recoge la doctrina del Tribunal Constitucional sobre la aplicación al derecho administrativo sancionador de los principios del orden penal, en los siguientes términos:

El Tribunal Constitucional ha declarado reiteradamente que los principios del orden penal, entre los que se encuentra el de culpabilidad, son de aplicación, con ciertos matices, al derecho administrativo sancionador, al ser ambos manifestaciones del ordenamiento punitivo del Estado (STC 18/1987 , 150/1991), y que no cabe en el ámbito sancionador administrativo la responsabilidad objetiva o sin culpa, en cuya virtud se excluye la posibilidad de imponer sanciones por el mero resultado, sin acreditar un mínimo de culpabilidad aun a título de mera negligencia (SSTC 76/1990 y 164/2005).

El principio de culpabilidad, garantizado por el artículo 25 de la Constitución, limita el ejercicio del "ius puniendi" del Estado y exige, según refiere el Tribunal Constitucional en la sentencia 129/2003, de 20 de junio, que la imposición de la sanción se sustente en la exigencia del elemento subjetivo de culpa, para garantizar el principio de responsabilidad y el derecho a un procedimiento sancionador con todas las garantías (STS de 1 de marzo de 2012, Rec 1298/2009).

Ciertamente, el principio de culpabilidad, previsto en el artículo 130.1 de la Ley 30/1992, de 26 noviembre, de Régimen Jurídico de las Administraciones Públicas y del Procedimiento Administrativo Común, dispone que solo pueden ser sancionados por hechos constitutivos de infracción administrativa los responsables de los mismos, aún a título de simple inobservancia. Obviamente, ello supone que dicha responsabilidad sólo puede ser exigida a título de dolo o culpa, quedando desterrada del ámbito del derecho administrativo sancionador la llamada "responsabilidad objetiva", y comprendiendo el título culposo la imprudencia, negligencia o ignorancia inexcusable. Esta "simple inobservancia" no puede ser entendida, por tanto, como la admisión en el derecho administrativo sancionador de la responsabilidad objetiva, pues la jurisprudencia mayoritaria de nuestro Tribunal Supremo (a partir de sus sentencias de 24 y 25 de enero y 9 de mayo de 1983) y la doctrina del Tribunal Constitucional (después de su STC 76/1990), destacan que el principio de culpabilidad, aún sin reconocimiento explícito en la Constitución, se infiere de los principios de legalidad y prohibición de exceso (artículo 25.1 CE), o de las propias exigencias inherentes a un Estado de Derecho, por lo que se requiere la existencia de dolo o culpa (en este sentido STS de 21 de enero de 2011, Rec 598/2008).

No obstante, el modo de atribución de responsabilidad a las personas jurídicas no se corresponde con las formas de culpabilidad dolosas o imprudentes que son imputables a la conducta humana. De modo que en el caso de infracciones cometidas por personas jurídicas, aunque haya de concurrir el elemento de la culpabilidad, éste se

aplica necesariamente de forma distinta a como se hace respecto de las personas físicas. Según la STC 246/1991 " (...) esta construcción distinta de la imputabilidad de la autoría de la infracción a la persona jurídica nace de la propia naturaleza de ficción jurídica a la que responden estos sujetos. Falta en ellos el elemento volitivo en sentido estricto, pero no la capacidad de infringir las normas a las que están sometidos. Capacidad de infracción y, por ende, reprochabilidad directa que deriva del bien jurídico protegido por la norma que se infringe y la necesidad de que dicha protección sea realmente eficaz y por el riesgo que, en consecuencia, debe asumir la persona jurídica que está sujeta al cumplimiento de dicha norma " (en este sentido STS de 24 de noviembre de 2011, Rec 258/2009).

A lo expuesto debe añadirse, siguiendo la sentencia de 23 de enero de 1998 , parcialmente transcrita en las SSTs de 9 de octubre de 2009, Rec 5285/2005 , y de 23 de octubre de 2010, Rec 1067/2006 , que "aunque la culpabilidad de la conducta debe también ser objeto de prueba, debe considerarse en orden a la asunción de la correspondiente carga, que ordinariamente los elementos volitivos y cognoscitivos necesarios para apreciar aquélla forman parte de la conducta típica probada, y que su exclusión requiere que se acredite la ausencia de tales elementos, o en su vertiente normativa, que se ha empleado la diligencia que era exigible por quien aduce su inexistencia; no basta, en suma, para la exculpación frente a un comportamiento típicamente antijurídico la invocación de la ausencia de culpa".

En el supuesto que nos atañe resulta notoria la existencia de antijuridicidad y culpabilidad en la conducta infractora de la entidad responsable del tratamiento de los datos personales, Vodafone, quien como responsable del tratamiento de datos de emisión de duplicados de tarjetas SIM, que decide sobre la finalidad, contenido y uso de los datos personales incluidos en el tratamiento, tiene la obligación de obrar con mayor diligencia a la hora de tramitar la emisión de duplicados, asegurándose de contar con el consentimiento de su titular, a fin de no incurrir en el tratamiento no consentido de sus datos personales. Dicha condición impone un deber especial de diligencia a la hora de llevar a cabo el uso o tratamiento de los datos personales, en lo que atañe al cumplimiento de los deberes que la legislación sobre protección de datos establece para garantizar los derechos fundamentales y las libertades públicas de las personas físicas, y especialmente su honor e intimidad personal y familiar, cuya intensidad se encuentra potenciada por la relevancia de los bienes jurídicos protegidos por aquellas normas y la profesionalidad de los responsables o encargados, máxime cuando operan con ánimo de lucro en el mercado de datos; en este sentido se ha pronunciado también la SAN 392/2015, de 17 de noviembre (Ver su Fundamento de Derecho Tercero).

Al respecto, resulta significativo que la operadora responsable del tratamiento no justifique debidamente la concurrencia en su conducta de la diligencia que le era exigible ni acredite la adopción de las cautelas exigibles para evitar el tratamiento no consentido del dato de carácter personal que nos ocupa (la emisión de duplicado de tarjeta SIM de forma fraudulenta), que debe atribuirse a la conducta negligente de Vodafone, que resulta del incumplimiento de su propia política de seguridad y procedimientos, así como por la falta de acreditación de las cautelas que manifiesta haber tomado, como la estipulada en el contrato.

En cuanto a la responsabilidad de Vodafone, debe indicarse que, con carácter general

Vodafone trata los datos de sus clientes al amparo de lo previsto en el artículo 6.1 b) del RGPD, por considerarse un tratamiento necesario para la ejecución de un contrato en el que el interesado es parte o para la aplicación a petición de este de medidas precontractuales. En otros casos, fundamenta la licitud del tratamiento en las bases previstas en el artículo 6.1.a), c), e) y f) del RGPD.

Por dicha razón, este es un proceso en donde la diligencia prestada por la operadora es fundamental para evitar este tipo de estafas y vulneraciones del RGPD.

Esta diligencia se manifiesta, en primer lugar, por el cumplimiento de su propia política de seguridad, lo cual no acaecido en el caso que nos ocupa. El Tribunal Constitucional señaló en su Sentencia 94/1998, de 4 de mayo, que nos encontramos ante un derecho fundamental a la protección de datos por el que se garantiza a la persona el control sobre sus datos, cualesquiera datos personales, y sobre su uso y destino, para evitar el tráfico ilícito de los mismos o lesivo para la dignidad y los derechos de los afectados; de esta forma, el derecho a la protección de datos se configura como una facultad del ciudadano para oponerse a que determinados datos personales sean usados para fines distintos a aquel que justificó su obtención.

Por su parte, en la Sentencia 292/2000, de 30 de noviembre, lo considera como un derecho autónomo e independiente que consiste en un poder de disposición y de control sobre los datos personales que faculta a la persona para decidir cuáles de esos datos proporcionar a un tercero, sea el Estado o un particular, o cuáles puede este tercero recabar, y que también permite al individuo saber quién posee esos datos personales y para qué, pudiendo oponerse a esa posesión o uso.

En cuanto a la conducta de Vodafone se considera que responde al título de culpa. Como depositaria de datos de carácter personal a gran escala, por lo tanto, habituada o dedicada específicamente a la gestión de los datos de carácter personal de los clientes, debe ser especialmente diligente y cuidadosa en su tratamiento.

Es el considerando 74 del RGPD el que dice: *Debe quedar establecida la responsabilidad del responsable del tratamiento por cualquier tratamiento de datos personales realizado por él mismo o por su cuenta. En particular, el responsable debe estar obligado a aplicar medidas oportunas y eficaces y ha de poder demostrar la conformidad de las actividades de tratamiento con el presente Reglamento, incluida la eficacia de las medidas. Dichas medidas deben tener en cuenta la naturaleza, el ámbito, el contexto y los fines del tratamiento, así como el riesgo para los derechos y libertades de las personas físicas.* Asimismo, el considerando 79 dice: *La protección de los derechos y libertades de los interesados, así como la responsabilidad de los responsables y encargados del tratamiento, también en lo que respecta a la supervisión por parte de las autoridades de control y a las medidas adoptadas por ellas, requieren una atribución clara de las responsabilidades en virtud del presente Reglamento, incluidos los casos en los que un responsable determine los fines y medios del tratamiento de forma conjunta con otros responsables, o en los que el tratamiento se lleve a cabo por cuenta de un responsable.*

QUINTA. - Subsidiariamente, y para el caso de que la Agencia entendiera que La parte reclamada ha infringido el artículo 6.1 del RGPD, no puede apreciarse la

existencia de culpabilidad en las infracciones imputadas a la parte reclamada y, en consecuencia, no puede imponerse a la misma sanción alguna.

Asimismo, solicita Vodafone con carácter subsidiario que esta Agencia acuerde el archivo del procedimiento por inexistencia de culpabilidad.

Rige en el Derecho Administrativo sancionador el principio de culpabilidad (artículo 28 de la Ley 40/2015, de Régimen Jurídico del Sector Público, LRJSP), por lo que el elemento subjetivo o culpabilístico es una condición indispensable para que surja la responsabilidad sancionadora. El artículo 28 de la LRJSP, “Responsabilidad”, dice:

“1. Sólo podrán ser sancionadas por hechos constitutivos de infracción administrativa las personas físicas y jurídicas, así como, cuando una Ley les reconozca capacidad de obrar, los grupos de afectados, las uniones y entidades sin personalidad jurídica y los patrimonios independientes o autónomos, que resulten responsables de los mismos a título de dolo o culpa.”

A la luz de este precepto la responsabilidad sancionadora puede exigirse a título de dolo o de culpa, siendo suficiente en el último caso la mera inobservancia del deber de cuidado.

El Tribunal Constitucional, entre otras, en su STC 76/1999, ha declarado que las sanciones administrativas participan de la misma naturaleza que las penales, al ser una de las manifestaciones del ius puniendi del Estado, y que, como exigencia derivada de los principios de seguridad jurídica y legalidad penal consagrados en los artículos 9.3 y 25.1 de la CE, es imprescindible su existencia para imponerlas.

A propósito de la culpabilidad de la persona jurídica procede citar la STC 246/1991, 19 de diciembre de 1991 (F.J. 2), conforme a la cual, respecto a las personas jurídicas, el elemento subjetivo de la culpa se ha de aplicar necesariamente de forma distinta a como se hace respecto de las personas físicas y añade que *“Esta construcción distinta de la imputabilidad de la autoría de la infracción a la persona jurídica nace de la propia naturaleza de ficción jurídica a la que responden estos sujetos. Falta en ellos el elemento volitivo en sentido estricto, pero no la capacidad de infringir las normas a las que están sometidos. Capacidad de infracción y, por ende, reprochabilidad directa que deriva del bien jurídico protegido por la norma que se infringe y la necesidad de que dicha protección sea realmente eficaz [...]”*.

La decisión de archivar un expediente sancionador podrá fundarse en la ausencia del elemento de la culpabilidad cuando el responsable de la conducta antijurídica hubiera obrado con toda la diligencia que las circunstancias del caso exigen.

En cumplimiento del principio de culpabilidad la AEPD ha acordado en numerosas ocasiones el archivo de procedimientos sancionadores en los que no concurría el elemento de la culpabilidad del sujeto infractor. Supuestos en los que, pese a existir un comportamiento antijurídico, había quedado acreditado que el responsable había obrado con toda la diligencia que resultaba exigible, por lo que no se apreciaba culpa alguna en su conducta. Ese ha sido el criterio mantenido por la Sala de lo Contencioso Administrativo, sección 1ª, de la Audiencia Nacional. Pueden citarse, por ser muy esclarecedoras, las siguientes sentencias:

- SAN de 26 de abril de 2002 (Rec. 895/2009) que dice:

“En efecto, no cabe afirmar la existencia de culpabilidad desde el resultado y esto es lo que hace la Agencia al sostener que al no haber impedido las medidas de seguridad el resultado existe culpa. Lejos de ello lo que debe hacerse y se echa de menos en la Resolución es analizar la suficiencia de las medidas desde los parámetros de diligencia media exigible en el mercado de tráfico de datos. Pues si se obra con plena diligencia, cumpliendo escrupulosamente los deberes derivados de una actuar diligente, no cabe afirmar ni presumir la existencia de culpa alguna.”

- SAN de 29 de abril de 2010, Fundamento Jurídico sexto, que, a propósito de una contratación fraudulenta, indica que *“La cuestión no es dilucidar si la recurrente trató los datos de carácter personal de la denunciante sin su consentimiento, como si empleó o no una diligencia razonable a la hora de tratar de identificar a la persona con la que suscribió el contrato”*.

Llegados a este punto, conviene recordar nuevamente lo que la STC 246/1991 ha dicho a propósito de la culpabilidad de la persona jurídica: que no falta en ella la *“capacidad de infringir las normas a las que están sometidos”*. *“Capacidad de infracción [...] que deriva del bien jurídico protegido por la norma que se infringe y la necesidad de que dicha protección sea realmente eficaz [...]”*.

En conexión con lo expuesto hay que referirse al artículo 5.2. del RGPD (principio de responsabilidad proactiva), conforme al cual el responsable del tratamiento será responsable del cumplimiento de lo dispuesto en el apartado 1- por lo que aquí interesa, del principio de licitud en relación con el artículo 6.1 del RGPD- y capaz de demostrar su cumplimiento. El principio de proactividad transfiere al responsable del tratamiento la obligación no solo de cumplir con la normativa, sino también la de poder demostrar dicho cumplimiento.

El Dictamen 3/2010, del Grupo de Trabajo del artículo 29 (GT29) -WP 173- emitido durante la vigencia de la derogada Directiva 95/46/CEE, pero cuyas reflexiones son aplicables en la actualidad, afirma que la *“esencia”* de la responsabilidad proactiva es la obligación del responsable del tratamiento de aplicar medidas que, en circunstancias normales, garanticen que en el contexto de las operaciones de tratamiento se cumplen las normas en materia de protección de datos y en tener disponibles documentos que demuestren a los interesados y a las Autoridades de control qué medidas se han adoptado para alcanzar el cumplimiento de las normas en materia de protección de datos.

El artículo 5.2 se desarrolla en el artículo 24 del RGPD que obliga al responsable a adoptar las medidas técnicas y organizativas apropiadas *“para garantizar y poder demostrar”* que el tratamiento es conforme con el RGPD. El precepto establece:

“Responsabilidad del responsable del tratamiento”

“1. Teniendo en cuenta la naturaleza, el ámbito, el contexto y los fines del tratamiento, así como los riesgos de diversa probabilidad y gravedad para los derechos y libertades de las personas físicas, el responsable del tratamiento aplicará medidas técnicas y organizativas apropiadas a fin de garantizar y poder demostrar que el tratamiento es conforme con el presente Reglamento. Dichas medidas se revisarán y actualizarán cuando sea necesario.”

2. Cuando sean proporcionadas en relación con las actividades de tratamiento, entre las medidas mencionadas en el apartado 1 se incluirá la aplicación, por parte del responsable del tratamiento, de las oportunas políticas de protección de datos.

3. La adhesión a códigos de conducta aprobados a tenor del artículo 40 o a un mecanismo de certificación aprobado a tenor del artículo 42 podrán ser utilizados como elementos para demostrar el cumplimiento de las obligaciones por parte del responsable del tratamiento.”

El artículo 25 del RGPD, “Protección de datos desde el diseño y por defecto”, establece:

“1. Teniendo en cuenta el estado de la técnica, el coste de la aplicación y la naturaleza, ámbito, contexto y fines del tratamiento, así como los riesgos de diversa probabilidad y gravedad que entraña el tratamiento para los derechos y libertades de las personas físicas, el responsable del tratamiento aplicará, tanto en el momento de determinar los medios de tratamiento como en el momento del propio tratamiento, medidas técnicas y organizativas apropiadas, como la seudonimización, concebidas para aplicar de forma efectiva los principios de protección de datos, como la minimización de datos, e integrar las garantías necesarias en el tratamiento, a fin de cumplir los requisitos del presente Reglamento y proteger los derechos de los interesados.

2.[...]”.

Es plenamente aplicable al caso la SAN de 17 de octubre de 2007 (rec. 63/2006), que, después de referirse a que las entidades en las que el desarrollo de su actividad conlleva un continuo tratamiento de datos de clientes y terceros han de observar un adecuado nivel de diligencia, dice: “[...] el Tribunal Supremo viene entendiendo que existe imprudencia siempre que se desatiende un deber legal de cuidado, es decir, cuando el infractor no se comporta con la diligencia exigible. Y en la valoración del grado de diligencia ha de ponderarse especialmente la profesionalidad o no del sujeto, y no cabe duda de que, en el caso ahora examinado, cuando la actividad de la recurrente es de constante y abundante manejo de datos de carácter personal ha de insistirse en el rigor y el exquisito cuidado por ajustarse a las prevenciones legales al respecto.

Por lo tanto, la parte reclamada no puede eludir su responsabilidad, ya que el RGPD exige que el responsable garantice no solo la existencia de medidas de seguridad, sino también su efectiva aplicación y supervisión. El incumplimiento de su propia política de seguridad especialmente cuando se trata de un procedimiento tan delicado como el duplicado de una tarjeta SIM, demuestra una falta de diligencia en su responsabilidad que justifica la imputación de la infracción.

SEXTA. - Subsidiariamente, y para el caso de que la Agencia entienda que ha existido infracción y deba imponerse una sanción a La parte reclamada, deberán tenerse en cuenta las siguientes circunstancias agravantes y atenuantes.

Vodafone solicita que se aprecien las siguientes circunstancias atenuantes:

- Que procedió a solventar la incidencia objeto de la reclamación de forma efectiva en cuanto tuvo conocimiento de los hechos.

- El grado de responsabilidad del responsable del tratamiento, habida cuenta de las medidas técnicas u organizativas que hayan aplicado en virtud de los artículos 25 y 32 del RGPD.
- El grado de cooperación con la autoridad de control con el fin de poner remedio a la infracción y mitigar los posibles efectos adversos de la infracción.
- Cualquier otro factor agravante o atenuante aplicable a las circunstancias del caso, como los beneficios financieros obtenidos o las pérdidas evitadas, directa o indirectamente, a través de la infracción.

Estas alegaciones se contestan en el apartado V (Sanción de multa: Determinación del importe).

III

Obligación incumplida

Se imputa a la parte reclamada la comisión de una infracción por vulneración del artículo 6 del RGPD, "Licitud del tratamiento", que señala en su apartado 1 los supuestos en los que el tratamiento de datos de terceros es considerado lícito:

"1. El tratamiento sólo será lícito si se cumple al menos una de las siguientes condiciones:

- a) el interesado dio su consentimiento para el tratamiento de sus datos personales para uno o varios fines específicos;
- b) el tratamiento es necesario para la ejecución de un contrato en el que el interesado es parte o para la aplicación a petición de este de medidas precontractuales;
- c) el tratamiento es necesario para el cumplimiento de una obligación legal aplicable al responsable del tratamiento;
- d) el tratamiento es necesario para proteger intereses vitales del interesado o de otra persona física;
- e) el tratamiento es necesario para el cumplimiento de una misión realizada en interés público o en el ejercicio de poderes públicos conferidos al responsable del tratamiento;
- f) el tratamiento es necesario para la satisfacción de intereses legítimos perseguidos por el responsable del tratamiento o por un tercero, siempre que sobre dichos intereses no prevalezcan los intereses o los derechos y libertades fundamentales del interesado que requieran la protección de datos personales, en particular cuando el interesado sea un niño. Lo dispuesto en la letra f) del párrafo primero no será de aplicación al tratamiento realizado por las autoridades públicas en el ejercicio de sus funciones".

A este respecto, conviene aclarar que, dentro del terminal móvil, va insertada la tarjeta SIM. Es una tarjeta inteligente, en formato físico y de reducidas dimensiones, que contiene un chip en el que se almacena la clave de servicio del suscriptor o abonado

usada para identificarse ante la red, esto es, el número de línea telefónica móvil del cliente MSISDN (Mobile Station Integrated Services Digital Network -Estación Móvil de la Red Digital de Servicios Integrados-), así como el número de identificación personal del abonado IMSI (International Mobile Subscriber Identity -Identidad Internacional del Abonado móvil-) pero también puede proporcionar otro tipo de datos como la información sobre el listado telefónico o el de llamadas y mensajes.

Por otro lado, la emisión de un duplicado de tarjeta SIM supone el tratamiento de los datos personales de su titular ya que se considerará persona física identificable toda persona cuya identidad pueda determinarse, directa o indirectamente, en particular mediante un identificador (artículo 4.1) del RGPD).

Por lo tanto, la tarjeta SIM identifica un número de teléfono y este número a su vez, identifica a su titular. En este sentido la Sentencia del TJUE en el asunto C-101/2001(Lindqvist) de 6.11.2003, apartado 24, Rec. 2003 p. I-12971: *«El concepto de "datos personales" que emplea el artículo 3, apartado 1, de la Directiva 95/46 comprende, con arreglo a la definición que figura en el artículo 2, letra a), de dicha Directiva "toda información sobre una persona física identificada o identificable". Este concepto incluye, sin duda, el nombre de una persona junto a su número de teléfono o a otra información relativa a sus condiciones de trabajo o a sus aficiones»*.

En suma, tanto los datos que se tratan para emitir un duplicado de tarjeta SIM como la tarjeta SIM (Subscriber Identity Module) que identifica de forma inequívoca y unívoca al abonado en la red, son datos de carácter personal, debiendo su tratamiento estar sujeto a la normativa de protección de datos.

En el presente caso, resulta acreditado en primer lugar que el día 2 de febrero de 2023 un tercero disponiendo de algunos datos de la parte reclamante (su número de teléfono, y siete de los ocho últimos dígitos de la cuenta bancaria en ese momento inscrita) pero no disponiendo de la contraseña de acceso al área privada y tampoco sin disponer de acceso a ningún teléfono de los registrados en el área privada para recibir una llamada del área de clientes de la parte reclamada, consiguió eludir en una llamada telefónica los controles de la política de seguridad de Lowi para la modificación de las credenciales de acceso del área privada de sus clientes, y que se modificaran esas credenciales (correo electrónico, contraseña).

Por otra parte, el tercero con sus nuevas credenciales logró acceder al área privada de la parte reclamante, conocer y modificar varios de sus datos personales. Vodafone manifiesta que tuvo que haber negligencia de la parte reclamante, pero no acredita que la hubiera.

Pues bien, el tercero consiguió suplantar la identidad de la parte reclamante, acceder a su área privada en Lowi y modificar algunos de sus datos personales en al menos otras tres ocasiones, los días 6, 13 y 16 de febrero de 2023, así como solicitar duplicados de tarjetas SIM en al menos tres ocasiones, los días 2, 6 y 16 de febrero.

Así las cosas, el tercero el 7 de febrero de 2023 recibió y consiguió activar una tarjeta SIM, lo que le permitió disfrutar del control del número de teléfono de la parte reclamante.

La parte reclamada facilitó duplicado de la tarjeta SIM de la línea de la reclamante, sin su consentimiento y sin verificar la identidad de dicho tercero. Así pues, la reclamada, no verificó la personalidad del que solicitó el duplicado de la tarjeta SIM, no verificó la personalidad de quien estaba activando tal duplicado de la tarjeta SIM, esto es, no tomó las cautelas necesarias para que estos hechos no se produjeran.

Hay que destacar, que tal como reconoce Vodafone *en su escrito de fecha 14 de septiembre de 2023*:

“Asimismo, el 14 de febrero de 2023, el Departamento de Fraude de Lowi califica el duplicado SIM como fraudulento, procediendo a identificar al reclamante como víctima de fraude e incluyendo en su ficha de cliente el aviso aportado en las alegaciones presentadas el 11 de agosto de 2023.”

El mencionado aviso de fraude en el sistema de Lowi tampoco fue eficaz en la llamada del día 16 de febrero de 2023, en la que el otro u otros consigue de nuevo modificar las credenciales de acceso al área privada y después solicitar a través del área privada otro duplicado de SIM, cuyo envío fue posteriormente cancelado y se restablecieron las credenciales de la parte reclamante el día siguiente.

Ahora bien, debe señalarse que el Sim Swapping es un fraude que permite suplantar la identidad mediante el secuestro del número de teléfono al obtener un duplicado de la tarjeta SIM.

En este sentido, la SAN, de fecha 19 de septiembre de 2023 (REC 403/2021), que dice: *“contrató un tercero sin control ni supervisión suficiente en cuanto no fue capaz de detectar que realmente, la persona que estaba manifestando su voluntad de contratar, no era quien decía ser. De haberse tomado las necesarias precauciones, a fin de asegurar la identidad de la persona contratante (por lo que hubiera sido bastante atender a la incorrecta contestación de las preguntas de identificación y verificación del cliente) se hubiera evitado la infracción del artículo 6.1 de la LOPD imputada por la AEP”*

En definitiva, en el caso analizado, queda en entredicho la diligencia empleada por parte de la reclamada para identificar a la persona que solicitó el duplicado de la tarjeta SIM.

En todo caso, no se siguió el procedimiento implantado por la parte reclamada, ya que, de haberlo hecho, se debió haber producido la denegación del mismo.

La parte reclamada no comprobó si previamente la línea estaba bloqueada o defectuosa, como recomienda su propia política de privacidad.

A la vista de lo anterior, Vodafone no logra acreditar que se haya seguido ese procedimiento de su propia política de seguridad y por consiguiente hubo un tratamiento ilícito de los datos personales de la parte reclamante, contraviniendo con ello el artículo 6 del RGPD.

En ese sentido el Considerando 40 del RGPD señala:

“(40) Para que el tratamiento sea lícito, los datos personales deben ser tratados con el consentimiento del interesado o sobre alguna otra base legítima establecida conforme

a Derecho, ya sea en el presente Reglamento o en virtud de otro Derecho de la Unión o de los Estados miembros a que se refiera el presente Reglamento, incluida la necesidad de cumplir la obligación legal aplicable al responsable del tratamiento o la necesidad de ejecutar un contrato en el que sea parte el interesado o con objeto de tomar medidas a instancia del interesado con anterioridad a la conclusión de un contrato.”

IV

Tipificación y calificación de la infracción

La infracción se tipifica en el artículo 83.5 del RGPD, que considera como tal:

“5. Las infracciones de las disposiciones siguientes se sancionarán, de acuerdo con el apartado 2, con multas administrativas de 20.000.000 EUR como máximo o, tratándose de una empresa, de una cuantía equivalente al 4% como máximo del volumen de negocio total anual global del ejercicio financiero anterior, optándose por la de mayor cuantía:

a) Los principios básicos para el tratamiento, incluidas las condiciones para el consentimiento a tenor de los artículos 5,6,7 y 9.”

La LOPDGD, a efectos de la prescripción de la infracción, califica en su artículo 72.1 de infracción muy grave, siendo en este caso el plazo de prescripción de tres años, *“b) El tratamiento de datos personales sin que concurra alguna de las condiciones de licitud del tratamiento establecidos en el artículo 6 del Reglamento (UE) 2016/679”.*

V

Sanción de multa: Determinación del importe

La determinación de la sanción que procede imponer en el presente caso exige observar las previsiones de los artículos 83.1 y 2 del RGPD, preceptos que, respectivamente, disponen lo siguiente:

“1. Cada autoridad de control garantizará que la imposición de las multas administrativas con arreglo al presente artículo por las infracciones del presente Reglamento indicadas en los apartados 4, 9 y 6 sean en cada caso individual efectivas, proporcionadas y disuasorias.”

“2. Las multas administrativas se impondrán, en función de las circunstancias de cada caso individual, a título adicional o sustitutivo de las medidas contempladas en el artículo 58, apartado 2, letras a) a h) y j). Al decidir la imposición de una multa administrativa y su cuantía en cada caso individual se tendrá debidamente en cuenta:

a) la naturaleza, gravedad y duración de la infracción, teniendo en cuenta la naturaleza, alcance o propósito de la operación de tratamiento de que se trate, así como el número de interesados afectados y el nivel de los daños y perjuicios que hayan sufrido;

b) la intencionalidad o negligencia en la infracción;

- c) cualquier medida tomada por el responsable o encargado del tratamiento para paliar los daños y perjuicios sufridos por los interesados;*
- d) el grado de responsabilidad del responsable o del encargado del tratamiento, habida cuenta de las medidas técnicas u organizativas que hayan aplicado en virtud de los artículos 25 y 32;*
- e) toda infracción anterior cometida por el responsable o el encargado del tratamiento;*
- f) el grado de cooperación con la autoridad de control con el fin de poner remedio a la infracción y mitigar los posibles efectos adversos de la infracción;*
- g) las categorías de los datos de carácter personal afectados por la infracción;*
- h) la forma en que la autoridad de control tuvo conocimiento de la infracción, en particular si el responsable o el encargado notificó la infracción y, en tal caso, en qué medida;*
- i) cuando las medidas indicadas en el artículo 58, apartado 2, hayan sido ordenadas previamente contra el responsable o el encargado de que se trate en relación con el mismo asunto, el cumplimiento de dichas medidas;*
- j) la adhesión a códigos de conducta en virtud del artículo 40 o a mecanismos de certificación aprobados con arreglo al artículo 42, y*
- k) cualquier otro factor agravante o atenuante aplicable a las circunstancias del caso, como los beneficios financieros obtenidos o las pérdidas evitadas, directa o indirectamente, a través de la infracción.”*

Dentro de este apartado, la LOPDGDD contempla en su artículo 76, titulado “Sanciones y medidas correctivas”:

“1. Las sanciones previstas en los apartados 4,5 y 6 del artículo 83 del Reglamento (UE) 2016/679 se aplicarán teniendo en cuenta los criterios de graduación establecidos en el apartado 2 del citado artículo.

“2. De acuerdo a lo previsto en el artículo 83.2.k) del Reglamento (UE) 2016/679 también podrán tenerse en cuenta:

- a) El carácter continuado de la infracción.*
- b) La vinculación de la actividad del infractor con la realización de tratamientos de datos personales.*
- c) Los beneficios obtenidos como consecuencia de la comisión de la infracción.*
- d) La posibilidad de que la conducta del afectado hubiera podido inducir a la comisión de la infracción.*

e) La existencia de un proceso de fusión por absorción posterior a la comisión de la infracción, que no puede imputarse a la entidad absorbente.

f) La afectación a los derechos de los menores.

g) Disponer, cuando no fuere obligatorio, de un delegado de protección de datos.

h) El sometimiento por parte del responsable o encargado, con carácter voluntario, a mecanismos de resolución alternativa de conflictos, en aquellos supuestos en los que existan controversias entre aquellos y cualquier interesado.”

Vodafone solicita que se aprecien las siguientes circunstancias atenuantes:

- Que procedió a solventar la incidencia objeto de la reclamación de forma efectiva en cuanto tuvo conocimiento de los hechos.
- El grado de responsabilidad del responsable del tratamiento, habida cuenta de las medidas técnicas u organizativas que hayan aplicado en virtud de los artículos 25 y 32 del RGPD.
- El grado de cooperación con la autoridad de control con el fin de poner remedio a la infracción y mitigar los posibles efectos adversos de la infracción.
- Cualquier otro factor agravante o atenuante aplicable a las circunstancias del caso, como los beneficios financieros obtenidos o las pérdidas evitadas, directa o indirectamente, a través de la infracción.

No se admite ninguna de las circunstancias invocadas.

La parte reclamada manifiesta que procedió a solventar la incidencia objeto de la reclamación de forma efectiva, pero hay que señalar que entra en el cumplimiento de sus obligaciones legales -por lo que aquí interesa del principio de licitud- la reclamada debe de actuar con la diligencia que las circunstancias del caso exigen y está obligada a cumplir su propia política de seguridad para de esta forma poder acreditar el cumplimiento de los principios de protección de datos.

A propósito del grado de diligencia que el responsable del tratamiento está obligado a desplegar cabe citar la sentencia de la Audiencia Nacional, Sala de lo Contencioso Administrativo, de 17 de octubre de 2007 (Rec. 63/2006) en la que recoge que “...el Tribunal Supremo viene entendiendo que existe imprudencia siempre que se desatiende un deber legal de cuidado, es decir, cuando el infractor no se comporta con la diligencia exigible. Y en la valoración del grado de diligencia ha de ponderarse especialmente la profesionalidad o no del sujeto, y no cabe duda de que, en el caso ahora examinado, cuando la actividad de la recurrente es de constante y abundante manejo de datos de carácter personal ha de insistirse en el rigor y el exquisito cuidado por ajustarse a las prevenciones legales al respecto”.

El Artículo 83.2.d) RGPD: “El grado de responsabilidad del responsable o del encargado del tratamiento, habida cuenta de las medidas técnicas u organizativas que hayan aplicado en virtud de los artículos 25 y 32;”.

La reclamada no acredita que se superara la política de seguridad pues incluso se estableció una clave que no se solicitó.

Por otra parte, el principio de proactividad supone transferir al responsable del tratamiento la obligación no solo de cumplir con la normativa, también la de poder demostrar su cumplimiento. Entre los mecanismos que el RGPD contempla para lograrlo se encuentran los previstos en el artículo 25, *“protección de datos desde el diseño”*, a tenor del cual el responsable debe aplicar *“tanto en el momento de determinar los medios de tratamiento como en el momento del propio tratamiento”* medidas técnicas y organizativas que garanticen que hace una efectiva aplicación de los principios del RGPD con ocasión de los tratamientos que realiza.

El artículo 83.2.f) del RGPD se refiere al *“grado de cooperación con la autoridad de control con el fin de poner remedio a la infracción y mitigar los posibles efectos adversos de la infracción”*.

La respuesta de la reclamada al requerimiento informativo de la Subdirección de Inspección no cumplía esas finalidades, por lo que no es encuadrable en esa circunstancia atenuante. En este sentido, no puede considerarse como cooperación voluntaria que busque activamente mitigar el impacto de la infracción el cumplimiento de la obligación legal de responder a los requerimientos de la autoridad de control, en el presente caso, la AEPD.

Según el RGPD, los responsables del tratamiento están obligados a cumplir con las solicitudes de información y a proporcionar la documentación requerida por las autoridades de control. Esta obligación es parte inherente de su responsabilidad y no constituye, en sí misma, una colaboración para remediar o mitigar los efectos de una infracción.

Asimismo, sobre la aplicación del artículo 76.2.c) de la LOPDGDD, en conexión con el artículo 83.2.k), inexistencia de beneficios obtenidos, cabe señalar que tal circunstancia solo puede operar como agravante y en ningún caso como circunstancia atenuante.

El artículo 83.2.k) del RGPD se refiere a *“cualquier otro factor agravante o atenuante aplicable a las circunstancias del caso, como los beneficios financieros obtenidos o las pérdidas evitadas, directa o indirectamente, a través de la infracción.”* Y el artículo 76.2c) de la LOPDGDD dice que *“2. De acuerdo a lo previsto en el artículo 83.2.k) del Reglamento (UE) 2016/679 también podrán tenerse en cuenta: [...] c) Los beneficios obtenidos como consecuencia de la comisión de la infracción.”* Ambas disposiciones mencionan como factor que puede tenerse en cuenta en la graduación de la sanción los “beneficios” obtenidos, pero no la “ausencia” de éstos, que es lo que Vodafone alega.

Además, conforme al artículo 83.1 del RGPD la imposición de las sanciones de multa está presidida por los siguientes principios: deberán estar individualizadas para cada caso particular, ser efectivas, proporcionadas y disuasorias. La admisión de que opere como una atenuante la ausencia de beneficios es contraria al espíritu del artículo 83.1 del RGPD y a los principios por los que se rige la determinación del importe de la

sanción de multa. Si a raíz de la comisión de una infracción del RGPD se califica como atenuante que no han existido beneficios, se anula en parte la finalidad disuasoria que se cumple a través de la sanción. Aceptar la tesis de Vodafone en un supuesto como el que nos ocupa supondría introducir una rebaja artificial en la sanción que verdaderamente procede imponerse; la que resulta de considerar las circunstancias del artículo 83.2 RGPD que sí deben de ser valoradas.

La Sala de lo Contencioso Administrativo de la Audiencia Nacional ha advertido que, el hecho de que en un supuesto concreto no estén presentes todos los elementos que integran una circunstancia modificativa de la responsabilidad que, por su naturaleza, tiene carácter agravante, no puede llevar a concluir que tal circunstancia es aplicable en calidad de atenuante. El pronunciamiento que hace la Audiencia Nacional en su SAN de 5 de mayo de 2021 (Rec. 1437/2020) -por más que esa resolución verse sobre la circunstancia del apartado e) del artículo 83.2. del RGPD, la comisión de infracciones anteriores- es extrapolable a la cuestión planteada, la pretensión de la reclamada de que se acepte como atenuante la “ausencia” de beneficios siendo así que tanto el RGPD como la LOPDGD se refieren solo a “los beneficios obtenidos”.

En aras a graduar el importe de la sanción de multa que se propone imponer a Vodafone por la infracción del artículo 6.1 del RGPD, estimamos que concurren las circunstancias a las que nos referiremos a continuación, que operan en calidad de agravantes:

- La circunstancia del artículo 83.2 e) RGPD: *“Toda infracción anterior cometida por el responsable o el encargado del tratamiento”.*

El considerando 148 del RGPD señala que “A fin de reforzar la aplicación de las normas del presente Reglamento [...]” e indica a ese respecto que “Debe no obstante, prestarse especial atención a [...] o a cualquier infracción anterior pertinente [...]”.

Así pues, conforme al apartado e) del artículo 83.2. RGPD, en la determinación del importe de la sanción de multa administrativa no podrán dejar de valorarse todas aquellas infracciones anteriores del responsable o del encargado de tratamiento en aras a calibrar la antijuricidad de la conducta analizada o la culpabilidad del sujeto infractor.

Además, una correcta interpretación de la disposición del artículo 83.2.e) RGPD no puede obviar la finalidad perseguida por la norma: decidir la cuantía de la sanción de multa administrativa en el caso individual planteado atendiendo siempre a que la sanción sea proporcional, efectiva y disuasoria.

Son numerosos los procedimientos sancionadores tramitados por la AEPD en los que la reclamada ha sido sancionada por la infracción del artículo 6.1 del RGPD:

i.EXP202204287 Resolución dictada el 24 de octubre de 2022 en la que se impuso una sanción de 70.000 euros. Los hechos versaron sobre un duplicado de la tarjeta SIM fraudulento sin legitimación. Vodafone se acogió a una de las dos reducciones previstas.

ii.EXP202203916. Resolución dictada el 24 de octubre de 2022 en la que se impuso una sanción de 70.000 euros. Los hechos versaron sobre un duplicado de la tarjeta SIM fraudulento sin legitimación. Vodafone se acogió a una de las dos reducciones previstas.

iii.EXP202203914 Resolución dictada el 24 de octubre de 2022 en la que se impuso una sanción de 70.000 euros. Los hechos versaron sobre un duplicado de la tarjeta SIM fraudulento sin legitimación. Vodafone se acogió a una de las dos reducciones previstas.

La reclamada argumenta que los anteriores procedimientos sancionadores, son relativos a clientes de Vodafone que no son clientes de la marca Lowi y cuyos duplicados SIM se tramitaron por canales diferentes al del caso aquí analizado, y por lo tanto no deben de ser aplicados como agravante.

En primer lugar, queda acreditado que Lowi es una marca bajo la misma denominación legal que Vodafone, son la misma empresa y por lo tanto no podrán dejar de valorarse todas aquellas infracciones anteriores del responsable o del encargado de tratamiento en aras a calibrar la antijuricidad de la conducta analizada o la culpabilidad del sujeto infractor.

En segundo lugar, no podemos compartir la interpretación que realiza la parte reclamada, pues el artículo 83.2 e) del RGPD a *“toda infracción cometida (...)”* sin entrar a valorar si ha de ser por hechos similares o no.

La finalidad de tal regulación no es otra que forzar el cumplimiento del RGPD, evitar el incumplimiento, fomentar el cumplimiento y que la infracción no resulte más rentable que el incumplimiento, es decir, que las multas sean disuasorias, tal y como indica el artículo 83.1 del RGPD.

Sentido en el que también se pronuncia la Sala Tercera de lo Contencioso-Administrativo del Tribunal Supremo en su sentencia de 11 de marzo de 2006 (recurso de casación 7133/2003): *“Ha de tenerse en cuenta, además, que uno de los criterios rectores de la aplicación de dicho principio régimen sancionador administrativo (criterio recogido bajo la rúbrica de <<principio de proporcionalidad>> en el apartado 2 del artículo 131 de la citada Ley 30/1992) es que la imposición de sanciones pecuniarias no debe suponer que la comisión de las infracciones tipificadas resulte más beneficiosa para el infractor que el cumplimiento de las normas infringidas”*.

- La evidente vinculación entre la actividad empresarial de la reclamada y el tratamiento de datos personales de clientes o de terceros (artículo 83.2.k, del RGPD en relación con el artículo 76.2.b, de la LOPDGDD).

La parte reclamada se ha opuesto en sus alegaciones a la aplicación de esta agravante.

También en ese caso los argumentos de la reclamada deben rechazarse:

La actividad empresarial de la reclamada trata necesariamente datos personales, siendo una de las compañías de telecomunicaciones más importantes de España.

Esta característica de su actividad empresarial repercute, reforzándola, en la diligencia que debe desplegar en el cumplimiento de los principios que presiden el tratamiento de datos de carácter personal y en la calidad y eficacia de las medidas técnicas y organizativas que debe tener implementadas para garantizar el respeto del derecho fundamental.

La Sentencia de la Audiencia Nacional de 17/10/2007 (rec. 63/2006), en la que, respecto de entidades cuya actividad lleva aparejado en continuo tratamiento de datos de clientes, indica que *“...el Tribunal Supremo viene entendiendo que existe imprudencia siempre que se desatiende un deber legal de cuidado, es decir, cuando el infractor no se comporta con la diligencia exigible. Y en la valoración del grado de diligencia ha de ponderarse especialmente la profesionalidad o no del sujeto, y no cabe duda de que, en el caso ahora examinado, cuando la actividad de la recurrente es de constante y abundante manejo de datos de carácter personal ha de insistirse en el rigor y el exquisito cuidado por ajustarse a las prevenciones legales al respecto.”*

Procede graduar la sanción a imponer a la reclamada y fijarla en la cuantía de 200.000 € por la por la presunta infracción del artículo 6.1) tipificada en el artículo 83.5.a) del citado RGPD.

Por lo tanto, de acuerdo con la legislación aplicable y valorados los criterios de graduación de las sanciones cuya existencia ha quedado acreditada, la Directora de la Agencia Española de Protección de Datos RESUELVE:

PRIMERO: IMPONER a VODAFONE ESPAÑA, S.A.U. con NIF A80907397, por una infracción del Artículo 6.1 del RGPD, tipificada en el Artículo 83.5 del RGPD, una multa de por un importe de 200.000 euros (doscientos mil euros).

SEGUNDO: NOTIFICAR la presente resolución a VODAFONE ESPAÑA, S.A.U. con NIF A80907397.

TERCERO: Esta resolución será ejecutiva una vez finalice el plazo para interponer el recurso potestativo de reposición (un mes a contar desde el día siguiente a la notificación de esta resolución) sin que el interesado haya hecho uso de esta facultad. Se advierte al sancionado que deberá hacer efectiva la sanción impuesta una vez que la presente resolución sea ejecutiva, de conformidad con lo dispuesto en el art. 98.1.b) de la ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas (en adelante LPACAP), en el plazo de pago voluntario establecido en el art. 68 del Reglamento General de Recaudación, aprobado por Real Decreto 939/2005, de 29 de julio, en relación con el art. 62 de la Ley 58/2003, de 17 de diciembre, mediante su ingreso, indicando el NIF del sancionado y el número de procedimiento que figura en el encabezamiento de este documento, en la cuenta restringida nº **IBAN: ES00-0000-0000-0000-0000-0000 (BIC/Código SWIFT: CAIXESBBXXX)**, abierta a nombre de la Agencia Española de Protección de Datos en la entidad bancaria CAIXABANK, S.A.. En caso contrario, se procederá a su recaudación en período ejecutivo.

Recibida la notificación y una vez ejecutiva, si la fecha de ejecutividad se encuentra entre los días 1 y 15 de cada mes, ambos inclusive, el plazo para efectuar el pago voluntario será hasta el día 20 del mes siguiente o inmediato hábil posterior, y si se

encuentra entre los días 16 y último de cada mes, ambos inclusive, el plazo del pago será hasta el 5 del segundo mes siguiente o inmediato hábil posterior.

De conformidad con lo establecido en el artículo 50 de la LOPDGDD, la presente Resolución se hará pública una vez haya sido notificada a los interesados.

Contra esta resolución, que pone fin a la vía administrativa conforme al art. 48.6 de la LOPDGDD, y de acuerdo con lo establecido en el artículo 123 de la LPACAP, los interesados podrán interponer, potestativamente, recurso de reposición ante la Directora de la Agencia Española de Protección de Datos en el plazo de un mes a contar desde el día siguiente a la notificación de esta resolución o directamente recurso contencioso administrativo ante la Sala de lo Contencioso-administrativo de la Audiencia Nacional, con arreglo a lo dispuesto en el artículo 25 y en el apartado 5 de la disposición adicional cuarta de la Ley 29/1998, de 13 de julio, reguladora de la Jurisdicción Contencioso-administrativa, en el plazo de dos meses a contar desde el día siguiente a la notificación de este acto, según lo previsto en el artículo 46.1 de la referida Ley.

Finalmente, se señala que conforme a lo previsto en el art. 90.3 a) de la LPACAP, se podrá suspender cautelarmente la resolución firme en vía administrativa si el interesado manifiesta su intención de interponer recurso contencioso-administrativo. De ser éste el caso, el interesado deberá comunicar formalmente este hecho mediante escrito dirigido a la Agencia Española de Protección de Datos, presentándolo a través del Registro Electrónico de la Agencia [<https://sedeagpd.gob.es/sede-electronica-web/>], o a través de alguno de los restantes registros previstos en el art. 16.4 de la citada Ley 39/2015, de 1 de octubre. También deberá trasladar a la Agencia la documentación que acredite la interposición efectiva del recurso contencioso-administrativo. Si la Agencia no tuviese conocimiento de la interposición del recurso contencioso-administrativo en el plazo de dos meses desde el día siguiente a la notificación de la presente resolución, daría por finalizada la suspensión cautelar.

Mar España Martí

Directora de la Agencia Española de Protección de Datos